

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC FPT**

**KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT HIỆN
VÀ PHẢN HỒI MỖI ĐE DỌA TỰ ĐỘNG SỬ DỤNG AI
TÁC TỬ (AGENTIC AI)**

thực hiện bởi

Nguyễn Đức Bình

Luận văn được nộp để đáp ứng yêu cầu
của học vị Thạc sĩ Kỹ thuật Phần mềm

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC FPT**

**KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT HIỆN
VÀ PHẢN HỒI MỐI ĐE DỌA TỰ ĐỘNG SỬ DỤNG AI
TÁC TỬ (AGENTIC AI)**

thực hiện bởi

Nguyễn Đức Bình

Luận văn được nộp để đáp ứng yêu cầu
của học vị Thạc sĩ Kỹ thuật Phần mềm

Giảng viên hướng dẫn:

TS. Bùi Văn Hiếu

TS. Đặng Văn Hiếu

Tóm tắt

Trong bối cảnh an ninh mạng hiện đại, các Trung tâm Điều hành An ninh mạng (SOC) luôn bị quá tải bởi số lượng cảnh báo khổng lồ, dẫn đến hội chứng "bội thực cảnh báo" và nguy cơ bỏ sót các Cuộc tấn công có chủ đích (APT) nghiêm trọng. Để giải quyết những hạn chế cố hữu của các hệ thống dựa trên luật tính truyền thống và nút thắt về độ trễ khi xử lý trực tiếp log mạng qua Mô hình Ngôn ngữ Lớn (LLM), luận văn này giới thiệu SENTINEL, một kiến trúc nhận thức hai tầng cho phát hiện và phản hồi mỗi đe dọa tự động. Khung đề xuất triển khai thuật toán thống kê trực tuyến Welford ở Tầng Truyền tải phi trạng thái (Tầng 1) để lọc lưu lượng vô hại ở tốc độ đường truyền với độ phức tạp thời gian và bộ nhớ $O(1)$, trong khi Tầng Tác tử Nhận thức (Tầng 2) dựa trên LangGraph — được trang bị cơ chế Sinh tăng cường truy xuất kép (Dual-RAG) trên các kỹ thuật MITRE ATT&CK và kịch bản NIST SP 800-61r2 — thực hiện suy luận ngữ cảnh có nền tảng phía sau các rào chắn mật mã.

Được đánh giá trên các bộ dữ liệu CSE-CIC-IDS2018 và DAPT2020, SENTINEL chỉ leo thang phần thiểu số lưu lượng thực sự mơ hồ lên LLM: tầng tắt định ra quyết định trong khoảng 0.6 ms so với 4–6 s cho mỗi lượt suy luận LLM, một sự tách biệt được kiểm định Mann-Whitney U xác nhận là có ý nghĩa thống kê ($p = 2.8 \times 10^{-17}$). Bộ lọc Welford trực tuyến bắt được toàn bộ bảy điểm dị biệt zero-day không chữ ký mà bộ máy tính bỏ sót, và cơ chế liên kết đa-ngày nổi lên trong Bộ nhớ Đe dọa bền vững đã phục hồi cả ba chiến dịch APT của DAPT2020 (recall = 1.0). Một đánh giá LLM-Trọng tài khác họ chấm chất lượng suy luận có nền tảng của tác tử đạt 3.91/5 tổng thể, với Faithfulness 4.00/5, trong khi thiết kế rào chắn phòng thủ nhiều lớp — Đóng gói Dữ liệu phân tách, làm sạch đầu ra, và chuỗi log HMAC — chặn toàn bộ tải trọng tiêm dựa trên mã hóa và định tuyến các thao túng ngữ nghĩa còn lại tới khâu duyệt của con người trong khi vẫn bảo toàn tính toàn vẹn pháp y. Các phát hiện này cho thấy việc kết hợp một bộ lọc tắt định tốc độ đường truyền với một tầng AI Tác tử có thể giải thích và được cô lập bằng mật mã mang lại một giải pháp tự động hóa an toàn, để mở rộng cho phòng thủ mạng hiện đại.

Lời cảm ơn

Tôi xin gửi lời biết ơn chân thành và sâu sắc nhất tới hai vị giảng viên hướng dẫn của tôi, TS. Bùi Văn Hiếu và TS. Đặng Văn Hiếu. Sự định hướng khoa học chuẩn xác, những phản hồi chuyên môn sắc bén cùng sự tận tâm và kiên nhẫn chỉ dạy của các thầy trong suốt chặng đường thực hiện đề tài chính là bệ đỡ vững chắc giúp tôi hoàn thành nghiên cứu này một cách trọn vẹn nhất.

Tôi cũng xin bày tỏ lòng biết ơn sâu sắc tới các giảng viên và cán bộ nhân viên tại Trường Đại học FPT, đặc biệt là Ban đào tạo chương trình Thạc sĩ Kỹ thuật Phần mềm (MSE), những người đã trang bị cho tôi nền tảng tri thức học thuật quý báu, tạo dựng một môi trường nghiên cứu chuyên nghiệp, hiện đại và hỗ trợ tối đa mọi điều kiện thuận lợi cho học viên trong suốt quá trình học tập.

Đồng thời, tôi xin gửi lời cảm ơn tới Ban lãnh đạo và các đồng nghiệp tại FPT Software, nơi tôi đang công tác. Sự tạo điều kiện về mặt thời gian, môi trường làm việc thực tế và những chia sẻ chuyên môn từ các đồng nghiệp đã giúp tôi có thêm nhiều động lực để hoàn thành tốt cả công việc tại cơ quan lẫn nhiệm vụ học tập nghiên cứu.

Cuối cùng và quan trọng nhất, tôi xin dành lời tri ân đặc biệt tới gia đình yêu thương của mình, đặc biệt là người vợ hiền cùng con nhỏ. Sự hy sinh thầm lặng, lòng kiên nhẫn, thấu hiểu và động viên tinh thần không ngừng nghỉ của gia đình trong những khoảng thời gian tôi bận rộn với các đợt thực nghiệm kéo dài chính là điểm tựa lớn nhất giúp tôi vững bước trên hành trình chinh phục học vị Thạc sĩ.

Danh sách hình vẽ

Hình 1.	Nút thắt nhận thức ở con người trong các hệ thống SOC truyền thống khi đối mặt với khối lượng cảnh báo vượt quá khả năng xử lý. (Nguồn: Tác giả)	16
Hình 2.	Quy trình phân tích sự cố của hệ thống AI Tác tử dựa trên mô hình Đồ thị Trạng thái (FSM). (Nguồn: Tác giả)	19
Hình 3.	Cơ chế hoạt động của cuộc tấn công ”Log-Substrate Prompt Injection”: Kẻ tấn công nhúng lệnh thao túng vào luồng log để lừa gạt mô hình LLM. (Nguồn: Tác giả)	21
Hình 4.	Sơ đồ kiến trúc tổng thể của hệ thống SENTINEL, minh họa luồng dữ liệu hai tầng và các thành phần cấu trúc. (Nguồn: Tác giả) . . .	26
Hình 5.	Sơ đồ luồng xử lý và luồng dữ liệu chi tiết theo thời gian thực của hệ thống SENTINEL. (Nguồn: Tác giả)	27
Hình 6.	Tỷ lệ chặn của rào chắn bảo mật theo từng nhóm tấn công đối kháng. (Nguồn: Tác giả)	42
Hình 7.	Độ chính xác dự báo tổng thể dưới thử nghiệm đối kháng. (Nguồn: Tác giả)	42

Danh sách bảng

Bảng 1.	So sánh các mô hình tự động hóa SOC và phát hiện mối đe dọa. (Nguồn: Tác giả)	13
Bảng 2.	Các mức lượng tử hóa cho mô hình Gemma-2-9B (giá trị xấp xỉ). (Nguồn: Tác giả)	17
Bảng 3.	Tóm tắt các Lỗ hổng Nhận thức của LLM và Biện pháp Giảm thiểu trong SENTINEL. (Nguồn: Tác giả)	22
Bảng 4.	Phân tích so sánh SENTINEL với các khung AI tác tử an ninh gần đây. (✓ = có; ~ = một phần; × = không; – = không áp dụng). (Nguồn: Tác giả)	24
Bảng 5.	Ma trận chuyển trạng thái của FSM Tác tử Nhận thức Tầng 2. (Nguồn: Tác giả)	29
Bảng 6.	So sánh các mô hình truy xuất trong chiến lược tìm kiếm lại. (Nguồn: Tác giả)	31
Bảng 7.	Thông số kỹ thuật lược đồ cơ sở dữ liệu Bộ nhớ Đe dọa. (Nguồn: Tác giả)	32
Bảng 8.	Nhân tấn công CSE-CIC-IDS2018, ánh xạ MITRE ATT&CK và hành động xử lý mặc định. (Nguồn: Tác giả)	37
Bảng 9.	Phân loại nhị phân ở Tầng 1 trên Luồng Gộp Thống nhất (4526 sự kiện). (Nguồn: Tác giả)	38
Bảng 10.	Phát hiện APT đa giai đoạn nổi lên trên chuỗi DAPT2020 (bộ nhớ sạch). (Nguồn: Tác giả)	39
Bảng 11.	Phát hiện zero-day (không-chữ-ký): bộ luật tĩnh so với điểm Z-score Welford. (Nguồn: Tác giả)	39
Bảng 12.	Ablation: Tầng 1 tắt định (Cấu hình A) so với SENTINEL hai tầng đầy đủ (Cấu hình F) trên 300 mẫu phân tầng. (Nguồn: Tác giả) . . .	40
Bảng 13.	Tỷ lệ chặn của tầng rào chắn tĩnh trên bộ 120 tải trọng đối kháng. (Nguồn: Tác giả)	41
Bảng 14.	Điểm chất lượng suy luận theo LLM-Trọng tài khác họ (trọng tài Llama-3-8B, tác tử Gemma-2-9B, $n = 188$ ca leo thang, thang 1–5). (Nguồn: Tác giả)	42
Bảng 15.	Tổng hợp kết quả trên năm chiều đánh giá. (Nguồn: Tác giả)	43

Danh mục các từ viết tắt

Từ viết tắt	Định nghĩa đầy đủ
AI	Artificial Intelligence (Trí tuệ nhân tạo)
APT	Advanced Persistent Threat (Mối đe dọa thường trực nâng cao)
C2	Command and Control (Chỉ huy và điều khiển)
CNN	Convolutional Neural Network (Mạng nơ-ron tích chập)
CPU	Central Processing Unit (Bộ vi xử lý trung tâm)
CSV	Comma-Separated Values (Định dạng dữ liệu phân tách bằng dấu phẩy)
CTI	Cyber Threat Intelligence (Tình báo mối đe dọa mạng)
CVE	Common Vulnerabilities and Exposures (Danh sách lỗ hổng bảo mật phổ biến)
DAG	Directed Acyclic Graph (Đồ thị có hướng không chu trình)
DAPT	Dynamic/Delayed Advanced Persistent Threat (Tấn công APT động/trễ)
DL	Deep Learning (Học sâu)
DoS	Denial of Service (Từ chối dịch vụ)
EDR	Endpoint Detection and Response (Phát hiện và phản hồi điểm cuối)
FAISS	Facebook AI Similarity Search (Tìm kiếm tương đồng AI của Facebook)
FSM	Finite State Machine (Máy trạng thái hữu hạn)
GGUF	GPT-Generated Unified Format (Định dạng hợp nhất do GPT tạo ra)
GPU	Graphics Processing Unit (Bộ xử lý đồ họa)
HITL	Human-in-the-Loop (Con người trong vòng lặp)
HMAC	Hash-based Message Authentication Code (Mã xác thực thông báo dựa trên hàm băm)
IDS	Intrusion Detection System (Hệ thống phát hiện xâm nhập)
IOC	Indicator of Compromise (Chỉ thị xâm nhập)
IP	Internet Protocol (Giao thức mạng Internet)
IPS	Intrusion Prevention System (Hệ thống ngăn ngừa xâm nhập)
JSON	JavaScript Object Notation (Định dạng đối tượng JavaScript)
LLM	Large Language Model (Mô hình ngôn ngữ lớn)
LRU	Least Recently Used (Ít sử dụng gần đây nhất)
LSTM	Long Short-Term Memory (Mạng bộ nhớ ngắn-dài hạn)

MAS	Multi-Agent System (Hệ thống đa tác tử)
ML	Machine Learning (Học máy)
NGFW	Next-Generation Firewall (Tường lửa thế hệ tiếp theo)
NIST	National Institute of Standards and Technology (Viện Tiêu chuẩn và Công nghệ Quốc gia Hoa Kỳ)
OWASP	Open Web Application Security Project (Dự án bảo mật ứng dụng web mở)
PCAP	Packet Capture (Dữ liệu bắt gói tin)
RAG	Retrieval-Augmented Generation (Sinh văn bản tăng cường truy xuất)
RAGAS	Retrieval Augmented Generation Assessment (Khung đánh giá chất lượng sinh tăng cường truy xuất)
RAM	Random Access Memory (Bộ nhớ truy cập ngẫu nhiên)
RBA	Runbook Automation (Tự động hóa kịch bản chạy)
RCE	Remote Code Execution (Thực thi mã từ xa)
RRF	Reciprocal Rank Fusion (Tổng hợp xếp hạng nghịch đảo)
SHA	Secure Hash Algorithm (Thuật toán băm an toàn)
SIEM	Security Information and Event Management (Quản lý thông tin và sự kiện an ninh)
SOC	Security Operations Center (Trung tâm điều hành an ninh mạng)
SQLi	SQL Injection (Tấn công tiêm lệnh SQL)
SSTI	Server-Side Template Injection (Tấn công tiêm khuôn mẫu máy chủ)
SVM	Support Vector Machine (Máy vector hỗ trợ)
TTP	Tactics, Techniques, and Procedures (Chiến thuật, kỹ thuật và quy trình)
TTL	Time to Live (Thời gian tồn tại)
URL	Uniform Resource Locator (Đường dẫn tài nguyên thống nhất)
VRAM	Video Random Access Memory (Bộ nhớ truy cập ngẫu nhiên video)
WAF	Web Application Firewall (Tường lửa ứng dụng web)
XSS	Cross-Site Scripting (Tấn công kịch bản chéo trang)

Mục lục

Tóm tắt	1
Lời cảm ơn	2
Danh mục các từ viết tắt	5
1 Giới thiệu	9
1.1 Bối cảnh và Động lực nghiên cứu	9
1.2 Mục tiêu Nghiên cứu	10
1.3 Câu hỏi Nghiên cứu	11
1.4 Đối tượng và Phạm vi Nghiên cứu	11
1.5 Phương pháp Nghiên cứu và Tổng quan Dữ liệu	12
1.6 Các Công trình Liên quan (Related Works)	12
1.7 Đóng góp của Luận văn	13
1.8 Cấu trúc của Luận văn	13
1.9 Tóm tắt chương	14
2 Cơ sở Lý thuyết	15
2.1 Tổng quan về Trung tâm Điều hành An ninh (SOC) và Nút thắt Nhận thức	15
2.2 Mô hình Ngôn ngữ Lớn (LLM) và Cơ sở Toán học của Lượng tử hóa	17
2.3 Kiến trúc AI Tác tử (Agentic AI) và Mô hình Đồ thị Trạng thái	18
2.4 Sinh Tăng cường Truy xuất (RAG) và Tối ưu hóa Tìm kiếm Lại	18
2.5 Lỗ hổng Nhận thức LLM và Vector Tấn công Prompt Injection	20
2.6 Thuật toán Thống kê Trực tuyến Welford	22
2.7 Các Nghiên cứu Liên quan: AI Tác tử cho Vận hành An ninh	23
2.8 Tóm tắt chương	24
3 Thiết kế Hệ thống và Triển khai Kỹ thuật	25
3.1 Tổng quan về Kiến trúc Nhận thức Hai tầng	25
3.2 Tầng 1: Bộ lọc Lưu lượng Mạng Thời gian thực (RuleEngine và Welford) .	28
3.3 Tầng 2: Tác tử AI Nhận thức LangGraph	29
3.4 Cơ chế Sinh Tăng cường Truy xuất Kép (Dual-RAG) và Bộ nhớ Ngữ nghĩa	30
3.5 Bộ nhớ Đề dọa và Liên kết Chiến dịch APT	31
3.6 Tầng Rào chắn Bảo mật AI (Guardrails)	33
3.7 Toàn vẹn Dữ liệu và Bảo vệ bằng Chuỗi HMAC	34
3.8 Giao diện Streamlit Bảng điều khiển Giám sát SOC (Streamlit UI)	34
3.9 Kiến trúc ảo hóa Docker và Triển khai hạ tầng	35
3.10 Tóm tắt chương	35
4 Thực nghiệm và Đánh giá	36

4.1	Môi trường Thực nghiệm và Bộ Dữ liệu	36
4.2	Chỉ số Đánh giá 5D và Thiết kế Nghiên cứu Loại trừ (Ablation Study) . .	37
4.3	Độ chính xác Phân loại trên Luồng Gộp Thống nhất	38
4.4	Phát hiện APT Đa giai đoạn (Liên kết Nổi lên)	38
4.5	Phát hiện Zero-Day bằng Điểm Dị biệt Welford	39
4.6	Nghiên cứu Loại trừ: Đánh đổi Độ trễ Hai tầng và Kiểm định Thống kê . .	40
4.7	Đánh giá Năng lực Phòng thủ Đối kháng (Bảo mật)	41
4.8	Toàn vẹn Dữ liệu và Chất lượng Suy luận (LLM Trọng tài)	41
4.9	Tổng hợp Kết quả Đánh giá 5D	43
5	Kết luận và Hướng phát triển	44
5.1	Tổng hợp Kết quả Nghiên cứu Đạt được	44
5.2	Đóng góp Khoa học và Thực tiễn	45
5.2.1	Đóng góp Khoa học	45
5.2.2	Đóng góp Thực tiễn	46
5.3	Các Giới hạn Hiện tại	46
5.4	Hướng Phát triển Tương lai	47
	Tài liệu tham khảo	48

Chương 1

Giới thiệu

Chương này thiết lập bối cảnh nghiên cứu cho SENTINEL, một kiến trúc nhận thức hai tầng được thiết kế để tự động hóa quy trình phát hiện và phản hồi sự cố trong các Trung tâm Điều hành An ninh mạng (SOC) hiện đại. Bằng việc phân tích các thách thức hệ thống như nạn bội thực cảnh báo, sự mù lòa của hệ thống dựa trên luật xác định và các giới hạn về tài nguyên tính toán của Mô hình Ngôn ngữ Lớn (LLM), nghiên cứu này trình bày chi tiết thiết kế và xác thực kiến trúc phát hiện lai bảo mật. Chương này phác họa các mục tiêu nghiên cứu, câu hỏi cốt lõi, phạm vi nghiên cứu và phương pháp kỹ thuật thực nghiệm định lượng được áp dụng để chứng minh tính hiệu quả của hệ thống đề xuất.

1.1 Bối cảnh và Động lực nghiên cứu

Mạng doanh nghiệp hiện đại đã chuyển đổi thành các môi trường đám mây không đồng nhất và có vành đai mở rộng, làm tăng đáng kể bề mặt tấn công tiềm ẩn. Sự gia tăng của các môi trường mạng phân tán toàn cầu đã chứng kiến sự dịch chuyển trong chiến thuật của kẻ tấn công từ các chữ ký phần mềm độc hại cô lập sang các chiến dịch Đe dọa Thường trực Nâng cao (APT) lén lút và đa giai đoạn [1], vốn đòi hỏi khả năng phân tích ngữ cảnh liên tục để phát hiện. Những tác nhân đe dọa tinh vi này tận dụng tải trọng đa hình và các kênh chỉ huy điều khiển (C2) để duy trì sự hiện diện lâu dài trong hệ thống.

Để giám sát và giảm thiểu sự cố mạng phát sinh từ các tác nhân trên, các Trung tâm Điều hành An ninh (SOC) hiện đại tiến hành tập hợp nhật ký hoạt động từ NGFW, IDS/IPS và EDR. Thông thường, quy trình phản hồi sự cố tiêu chuẩn sẽ hợp nhất các nguồn nhật ký này về hệ thống Quản lý Thông tin và Sự kiện An ninh (SIEM) trung tâm [2] nhằm mục đích chuẩn hóa dữ liệu và đối sánh tương quan. Tuy nhiên, khối lượng và tốc độ của dữ liệu nhật ký thu nạp khổng lồ đã dẫn đến một "Nghịch lý Dữ liệu Lớn" trong an ninh mạng [3], gây quá tải và làm chậm tốc độ ứng phó sự cố khẩn cấp.

Sự quá tải dữ liệu log này trực tiếp gây ra hội chứng bội thực cảnh báo nghiêm trọng. Các hoạt động giám sát tại SOC thường bị tê liệt khi các chuyên viên phân tích bị ngập chìm

trong hàng ngàn cảnh báo dung lượng lớn nhưng chất lượng thấp, vốn phần lớn là các cảnh báo dương tính giả được sinh ra do nhiễu nền hoặc cấu hình sai của hệ thống [5]. Sự quá tải nhận thức này làm tăng đáng kể nguy cơ bỏ sót các chỉ báo xâm nhập thực sự nguy hiểm.

Thêm vào đó, các hệ thống phát hiện xâm nhập truyền thống vẫn phụ thuộc chặt chẽ vào cơ sở dữ liệu chữ ký tĩnh và các bộ quy tắc thủ công [10], khiến chúng mất đi khả năng nhận biết trước các biến thể đe dọa mới. Dù có hiệu quả với các mối đe dọa đã biết, chúng hoàn toàn mù lòa trước các lỗ hổng Zero-day hoặc mã độc đa hình vốn dễ dàng vượt qua các luật tĩnh bằng những thay đổi tải trọng cực nhỏ.

Để tiết kiệm chi phí lưu trữ nhật ký mạng và tài nguyên xử lý, nhiều SOC thực hiện lấy mẫu ngẫu nhiên hoặc cắt xén dữ liệu log một cách thụ động. Tuy nhiên, các kỹ thuật giảm thiểu dữ liệu thô thiển này gây tổn hại nghiêm trọng đến việc điều tra số do làm đứt gãy chuỗi bằng chứng thời gian cần thiết để liên kết và tái dựng hành vi "chậm và ẩn nấp" của các chiến dịch APT vốn diễn ra lén lút trong nhiều tuần hoặc nhiều tháng [4], khiến các hoạt động di chuyển ngang dài hạn trở nên hoàn toàn vô hình.

Mặc dù các Mô hình Ngôn ngữ Lớn (LLM) có thể tự động hóa quy trình phân loại bằng cách tóm tắt log và lập kế hoạch ứng phó sự cố, việc tích hợp trực tiếp chúng vào SOC gặp phải một nghịch lý tích hợp chứa hai nút thắt lớn đan xen. Thứ nhất, việc suy luận trực tiếp các dòng log mạng thô qua LLM hàng tỷ tham số là bất khả thi về mặt hiệu năng do cơ chế tự chú ý (self-attention) của Transformer có độ phức tạp tính toán bậc hai gây ra độ trễ cao [16]. Thứ hai, tích hợp trực tiếp giao diện ngôn ngữ tự nhiên làm lộ diện hệ thống trước các rủi ro bảo mật AI đối kháng, tiêu biểu là các cuộc tấn công tiêm prompt từ log (log-substrate prompt injection) nơi kẻ tấn công lợi dụng việc mờ nhạt ranh giới giữa lệnh điều khiển và dữ liệu thô trong LLM [9]. Chỉ dẫn độc hại nhúng trong các trường log (như User-Agent) có thể chiếm quyền điều khiển suy luận của LLM nếu không có cơ chế cô lập nghiêm ngặt. Để giải quyết các nút thắt này, hệ thống SENTINEL đề xuất kiến trúc hai tầng: Tầng 1 lọc dữ liệu không trạng thái ở tốc độ đường truyền, và Tầng 2 thực thi suy luận AI Tác tử được cô lập bảo mật.

1.2 Mục tiêu Nghiên cứu

Mục tiêu tổng quát của nghiên cứu này là thiết kế, triển khai và đánh giá định lượng kiến trúc nhận thức hai tầng SENTINEL, kết hợp giữa bộ lọc bất thường thông kê trễ thấp và quy trình suy luận AI Tác tử có trạng thái được bảo vệ an toàn. Mục tiêu chung này được cụ thể hóa thành ba mục tiêu kỹ thuật. Thứ nhất, xây dựng một cơ chế lọc tốc độ đường truyền triển khai thuật toán thống kê trực tuyến Welford với độ phức tạp tính toán và bộ nhớ $O(1)$ để tính phương sai cuộn cùng điểm Z-Score, qua đó loại bỏ lưu lượng mạng vô hại ngay ở tốc độ đường truyền và giảm thiểu nạn bội thực cảnh báo tại tầng thu nạp. Thứ hai, thiết kế

một tác tử nhận thức có trạng thái dựa trên LangGraph và các LLM lượng tử hóa cục bộ, tích hợp rào chắn bảo mật đầu vào–đầu ra, có khả năng phân tích an toàn các cảnh báo bất thường đồng thời vô hiệu hóa các vector tấn công đối kháng nhắm vào hệ thống tích hợp LLM. Thứ ba, kiến tạo một phân hệ truy xuất nền tảng kép (Dual-RAG) hợp nhất các kỹ thuật MITRE ATT&CK với các kịch bản NIST SP 800-61r2 nhằm làm nền tảng cho quyết định phản hồi của tác tử và giảm thiểu ảo giác thông tin.

1.3 Câu hỏi Nghiên cứu

Để dẫn đường cho việc kiểm chứng thực nghiệm và xác định các giới hạn hiệu năng của kiến trúc đề xuất, nghiên cứu này giải quyết ba câu hỏi nghiên cứu cốt lõi. Câu hỏi thứ nhất (RQ1) đặt vấn đề làm thế nào để thiết kế về mặt toán học một cơ chế lọc lưu lượng mạng thời gian thực dựa trên các baseline thống kê trực tuyến sao cho hoạt động ở tốc độ đường truyền và giảm thiểu nạn bội thực cảnh báo trong khi vẫn bảo toàn chuỗi sự kiện theo thời gian của các chiến dịch APT. Câu hỏi thứ hai (RQ2) đặt vấn đề về phương pháp kiến trúc nào cho phép tích hợp các LLM cục bộ vào quy trình phản hồi sự cố tự động, đi kèm cơ chế đóng gói dữ liệu đầu vào–đầu ra an toàn, nhằm giảm thiểu độ trễ đồng thời ngăn ngừa các vector tấn công đối kháng nhắm vào hệ thống. Câu hỏi thứ ba (RQ3) đặt vấn đề về hiệu quả thực nghiệm thu được khi tăng cường bộ nhớ của tác tử tự trị bằng một hệ thống truy xuất tri thức kép dựa trên thuật toán Reciprocal Rank Fusion (RRF), được đo lường qua mức cải thiện độ chính xác phân loại mối đe dọa và mức giảm ảo giác thông tin.

1.4 Đối tượng và Phạm vi Nghiên cứu

Đối tượng Nghiên cứu: Đối tượng nghiên cứu của luận văn bao gồm các quy trình tự động hóa phản hồi sự cố mạng trong Trung tâm Điều hành An ninh (SOC) hiện đại; các loại log luồng mạng tốc độ cao (NetFlow/IPFIX) và siêu dữ liệu bắt gói tin (PCAP); cơ chế điều phối và duy trì trạng thái nhận thức của tác tử (LangGraph); các mô hình ngôn ngữ lớn cục bộ được lượng tử hóa để tối ưu hiệu năng; và các vector tấn công đối kháng nhắm vào cỗ máy AI (như tiêm prompt từ log, buôn lậu dấu phân tách, đầu độc tri thức RAG).

Phạm vi Nghiên cứu: Về phạm vi nghiên cứu thực nghiệm, đánh giá được giới hạn trên tập dữ liệu CSE-CIC-IDS2018 [1] (đại diện cho tấn công mạng phổ biến) và DAPT2020 [25] (đại diện cho chiến dịch APT đa giai đoạn), trong đó các tấn công Zero-day được mô hình hóa thực tế bằng cách đẩy đặc trưng của dòng lưu lượng lành tính lên cực đại thông qua thuật toán Welford. Về mặt mô hình và phần cứng, hệ thống được kiểm thử trên LLM cục bộ (*Gemma-2-9B-IT*) lượng tử hóa Q6_K chạy trên một GPU thương mại duy nhất nhằm đảm bảo tính riêng tư và chủ quyền dữ liệu trong môi trường cách ly (air-gapped). Hơn nữa,

các hành động tự trị của tác tử phản hồi được giới hạn ở việc lập báo cáo pháp y và tạo quy tắc tường lửa mô phỏng, loại trừ việc ngắt kết nối mạng vật lý tự động để tránh rủi ro gián đoạn vận hành hệ thống.

1.5 Phương pháp Nghiên cứu và Tổng quan Dữ liệu

Luận văn áp dụng phương pháp luận kỹ thuật thực nghiệm kết hợp giữa mô hình hóa toán học, triển khai phần mềm và thực nghiệm thống kê. Nghiên cứu kết hợp giữa lập luận diễn dịch, áp dụng các mô hình toán học và máy trạng thái hữu hạn (FSM) để thiết kế hệ thống, với việc xác thực thực nghiệm. Cụ thể, các mô hình lập luận riêng bao gồm lập luận thống kê ở Tầng 1 để phát hiện bất thường thời gian thực khi Z-Score vượt ngưỡng $\alpha > 3.5\sigma$; lập luận nhận thức ở Tầng 2 để mô hình hóa quy trình phân tích và quyết định dưới dạng đồ thị trạng thái qua LangGraph; và lập luận đối kháng để đánh giá giới hạn phòng thủ của các rào chắn trước tấn công tiêm prompt và buôn lậu dấu phân tách.

Phương pháp nghiên cứu được thực hiện qua ba bước triển khai chính. Bước thứ nhất là triển khai hệ thống, phát triển các thành phần trong kiến trúc hai tầng sử dụng Python, FAISS, LangGraph, llama.cpp và đóng gói bằng Docker. Bước thứ hai là thực nghiệm, chạy 22 kịch bản End-to-End (E2E) trên luồng dữ liệu Unified Stream để mô phỏng cả dữ liệu tĩnh và luồng Redis stream trực tuyến, đồng thời thử nghiệm tấn công đối kháng. Bước thứ ba là đánh giá thống kê, đo lường hệ thống qua khung chỉ số năm chiều (Độ chính xác, Bảo mật, Hiệu suất, Tính toàn vẹn, Nhận thức) và kiểm chứng sự cải thiện bằng kiểm định McNemar và Mann-Whitney U.

Cuối cùng, các dữ liệu thực nghiệm thu thập được phân loại rõ ràng thành các biến định lượng và các đánh giá định tính được định lượng hóa. Dữ liệu định lượng bao gồm các biến số đo lường mạng như thời gian luồng, cổng dịch vụ, dung lượng byte, số gói tin và các chỉ số hiệu năng hệ thống như độ trễ, precision, recall và F1-score. Ngược lại, dữ liệu định tính gồm các nội dung lập luận và giải thích bằng ngôn ngữ tự nhiên của LLM sẽ được định lượng hóa thành thang điểm dựa trên các chỉ số của khung đánh giá RAGAS [26] như Faithfulness, Answer Relevancy, Context Precision và Recall.

1.6 Các Công trình Liên quan (Related Works)

Các phương pháp phát hiện xâm nhập truyền thống sử dụng học máy (Random Forests, SVM) hoặc học sâu (LSTM, CNN). Tuy nhiên, chúng là những "hộp đen" thiếu tính giải thích. Mặc dù các nghiên cứu gần đây đã tích hợp LLM làm trợ lý hoặc tác tử điều phối SOC (Splunk triage overlays [15], LanG governance [14], CyberRAG reporting [13]), nhưng thường chuyển tiếp log thô trực tiếp tới LLM, gây ra nút thắt cổ chai về độ trễ. Quan trọng

hơn, các hệ thống đa tác tử hiện tại thiếu khả năng bảo mật nhận thức để tự bảo vệ trước tấn công log-substrate prompt injection [12]. SENTINEL giải quyết khoảng trống này bằng cách kết hợp lọc thông kê Welford trễ thấp với cơ chế đóng gói dữ liệu phân tách để bảo vệ lõi suy luận của tác tử. Một so sánh toàn diện của các mô hình này đối với kiến trúc SENTINEL trên các khía cạnh vận hành cốt lõi được trình bày trong Bảng 1.

Bảng 1. So sánh các mô hình tự động hóa SOC và phát hiện mối đe dọa. (Nguồn: Tác giả)

Khía cạnh / Mô hình	SIEM truyền thống (Luật tĩnh)	ML/DL-based IDS	Phân loại LLM thông thường	SENTINEL (Đề xuất)
Băng thông / Tốc độ	Cực cao ($O(1)$)	Cao (1–10 ms)	Rất thấp (4–10 s)	Cao (tăng tốc độ lại)
Tính giải thích	Cao (luật tĩnh)	Thấp (hộp đen)	Cao (văn bản)	Rất cao (kịch bản)
Bảo mật đối kháng	Cao (không dùng LLM)	Trung bình (tránh né)	Rất thấp (tiêm prompt)	Cao (có rào chắn)
Liên kết APT	Kém (không trạng thái)	Trung bình (LSTMs)	Kém (giới hạn ngữ cảnh)	Cao (Bộ nhớ Đe dọa)

1.7 Đóng góp của Luận văn

Các đóng góp chính của luận văn này bao gồm ba khía cạnh chính. Về mặt kiến trúc, nghiên cứu đề xuất và chứng minh tính hiệu quả của mô hình lai hai tầng, giải quyết mâu thuẫn giữa hiệu năng xử lý tốc độ đường truyền và khả năng suy luận ngữ cảnh sâu. Về mặt bảo mật AI, luận văn cung cấp bằng chứng thực nghiệm về hiệu quả của đóng gói dữ liệu phân tách (Delimited Data Encapsulation) và chuỗi HMAC trong việc chống tiêm prompt và đầu độc dữ liệu. Về mặt điều phối tự động, nghiên cứu thay thế kịch bản tự động hóa tĩnh (RBA) bằng mô hình tác tử tự trị linh hoạt dựa trên đồ thị trạng thái LangGraph.

1.8 Cấu trúc của Luận văn

Phần còn lại của luận văn được tổ chức thành năm chương chính. Chương 1 giới thiệu bối cảnh nghiên cứu, mục tiêu, câu hỏi nghiên cứu, phương pháp luận và các công trình liên quan. Chương 2 thiết lập cơ sở lý thuyết và nền tảng toán học cho lượng tử hóa LLM, mô hình đồ thị trạng thái, RAG và mô hình thống kê trực tuyến. Chương 3 trình bày chi tiết thiết kế hệ thống và triển khai kỹ thuật của kiến trúc SENTINEL đề xuất, bao gồm bộ lọc Tầng 1, tác tử Tầng 2, cơ chế RAG kép, rào chắn bảo mật AI, cấu trúc bảng điều khiển Streamlit và hạ tầng ảo hóa Docker. Chương 4 báo cáo kết quả thực nghiệm, nghiên cứu

loại trừ và kiểm định thống kê. Cuối cùng, Chương 5 tóm tắt các phát hiện chính, thảo luận giới hạn hệ thống và đề xuất hướng nghiên cứu tương lai.

1.9 Tóm tắt chương

Chương này đã phác thảo khung nghiên cứu cho hệ thống SENTINEL. Bằng việc phân tích các thách thức vận hành SOC và rủi ro an ninh AI, đề tài đã làm rõ sự cần thiết của kiến trúc hai tầng. Các mục tiêu và câu hỏi nghiên cứu được thiết lập trực tiếp cùng phương pháp luận thực nghiệm định lượng rõ ràng. Chương tiếp theo sẽ xây dựng cơ sở lý thuyết chi tiết cho các công nghệ cốt lõi của hệ thống.

Chương 2

Cơ sở Lý thuyết

Chương này thiết lập các nền tảng lý thuyết và cơ sở khoa học chuyên sâu làm chỗ dựa vững chắc cho việc thiết kế và triển khai hệ thống SENTINEL. Trọng tâm nghiên cứu được triển khai mạch lạc thông qua cấu trúc phân tầng logic: bắt đầu bằng việc mổ xẻ các nút thắt nhận thức và hiện tượng quá tải thông tin tại các Trung tâm Điều hành An ninh (SOC) hiện đại; tiếp nối bởi nền tảng toán học của việc tối ưu hóa hiệu năng suy luận thông qua lượng tử hóa Mô hình Ngôn ngữ Lớn (LLM) cục bộ; phân tích cơ chế điều phối có trạng thái của kiến trúc AI Tác tử (Agentic AI) dựa trên đồ thị có hướng; cơ chế củng cố tri thức chuyên ngành bằng giải pháp Sinh tăng cường Truy xuất (RAG) lai; nhận diện các vector tấn công đối kháng đặc thù nhắm vào LLM trong môi trường xử lý log; và cuối cùng là toán học hóa thuật toán thống kê trực tuyến Welford phục vụ lọc dữ liệu tốc độ cao và mô phỏng đe dọa zero-day thực tế.

2.1 Tổng quan về Trung tâm Điều hành An ninh (SOC) và Nút thắt Nhận thức

Các Trung tâm Điều hành An ninh (SOC) đóng vai trò là tuyến phòng thủ hạt nhân trong việc bảo vệ hạ tầng công nghệ thông tin của doanh nghiệp, thực hiện giám sát thông qua việc hợp nhất luồng dữ liệu đo lường từ xa từ các thiết bị tường lửa thế hệ mới (NGFW), hệ thống giám sát điểm cuối (EDR) và các cảm biến phân tích lưu lượng mạng (IDS/IPS). Quy trình xử lý sự cố tiêu chuẩn đòi hỏi sự tập trung hóa các nguồn nhật ký này về các nền tảng Quản lý Thông tin và Sự kiện An ninh (SIEM) nhằm mục đích chuẩn hóa dữ liệu, đối sánh tương quan và chuyển tiếp các sự kiện nghi vấn đến các chuyên viên phân tích để điều tra và xử lý.

Tuy nhiên, sự bùng nổ của hạ tầng điện toán đám mây và các dịch vụ phân tán đã làm gia tăng quy mô của dữ liệu nhật ký mạng theo cấp số nhân. Việc gia tăng lưu lượng telemetry này trực tiếp gây ra hội chứng bội thực cảnh báo hệ thống. Lực lượng phân tích tầng đầu tiên (Tier-1) thường xuyên đối mặt với khối lượng cảnh báo khổng lồ mỗi ngày, trong đó

các trường hợp dương tính giả (false positives) chiếm tỷ lệ áp đảo. Hiện tượng cạn kiệt tài nguyên chủ yếu do dòng thác cảnh báo liên tục làm suy giảm đáng kể năng lực xử lý nhận thức của con người, từ đó gia tăng xác suất bỏ sót các hành vi xâm nhập thực sự nguy hiểm [5].



Hình 1. Nút thắt nhận thức ở con người trong các hệ thống SOC truyền thống khi đối mặt với khối lượng cảnh báo vượt quá khả năng xử lý. (Nguồn: Tác giả)

Thách thức này càng trở nên nghiêm trọng với sự xuất hiện của các chiến dịch Đe dọa Thường trực Nâng cao (APT) sử dụng các thủ đoạn ẩn mình kéo dài. Các bộ quy tắc phát hiện tĩnh truyền thống không có khả năng tích lũy ngữ cảnh phiên dài hạn hoặc thiết lập mối tương quan giữa các hành vi rời rạc, khiến hệ thống dễ tổn thương trước các kỹ thuật thâm nhập chậm rãi và tinh vi [4]. Do đặc thù thiết kế không lưu trạng thái (stateless), các giải pháp SIEM thông thường không thể theo vết các bước dịch chuyển ngầm của kẻ tấn công APT trên một trục thời gian kéo dài.

2.2 Mô hình Ngôn ngữ Lớn (LLM) và Cơ sở Toán học của Lượng tử hóa

Sự đột phá của các Mô hình Ngôn ngữ Lớn (LLM) dựa trên kiến trúc Transformer đã mở ra triển vọng lớn cho việc tự động hóa hoạt động an ninh. Hiệu quả của chúng bắt nguồn từ cơ chế tự chú ý (self-attention), vốn cân nhắc song song mối liên hệ giữa mọi token với tất cả các token còn lại trong chuỗi [16]; nhờ đặc tính này, mô hình nắm bắt được các phụ thuộc tầm xa cần thiết để đối chiếu những sự kiện nằm rải rác trong một luồng nhật ký kéo dài.

Mặc dù vậy, việc ứng dụng LLM trong môi trường SOC bị ràng buộc chặt chẽ bởi các nguyên tắc về chủ quyền dữ liệu. Việc chuyển tiếp dữ liệu đo lường mạng nội bộ nhạy cảm đến các máy chủ đám mây của bên thứ ba vi phạm nghiêm trọng các quy định tuân thủ bảo mật và kiến trúc an ninh không tin cậy (Zero Trust) [31], đặt ra yêu cầu bắt buộc phải vận hành các mô hình LLM cục bộ (Local LLM) trong môi trường mạng cách ly (air-gapped).

Bên cạnh đó, việc thực thi các mô hình có quy mô hàng tỷ tham số tại chỗ đòi hỏi tài nguyên phần cứng cực kỳ lớn. Ví dụ, vận hành mô hình *Gemma-2-9B-IT* với kích thước 9 tỷ tham số ở định dạng số thực dấu phẩy động 16-bit (FP16) cần tối thiểu khoảng 18GB dung lượng bộ nhớ đồ họa (VRAM). Để hiện thực hóa khả năng suy luận trên các phần cứng thương mại phổ thông, kỹ thuật lượng tử hóa mô hình (Model Quantization) được áp dụng. Về bản chất, lượng tử hóa tái ánh xạ các trọng số liên tục có độ chính xác cao của mô hình (ví dụ số thực dấu phẩy động 16-bit) sang một lưới số nguyên thưa hơn với số bit thấp (ví dụ 4-bit), đánh đổi một mức mất mát độ chính xác có kiểm soát để tiết kiệm đáng kể bộ nhớ [17]. Việc ứng dụng định dạng tập tin GGUF kết hợp tiêu chuẩn lượng tử hóa Q6_K thông qua thư viện `llama.cpp` giúp giảm dung lượng bộ nhớ xuống còn khoảng 7–8 GB VRAM (mức cắt giảm trên 50%), tối đa hóa tốc độ xử lý suy luận trong khi vẫn bảo toàn được năng lực lập luận logic của mô hình. Bảng 2 đối chiếu các mức lượng tử hóa liên quan cho mô hình 9 tỷ tham số và lý giải việc lựa chọn Q6_K như một điểm cân bằng giữa dung lượng bộ nhớ và độ trung thực của suy luận.

Bảng 2. Các mức lượng tử hóa cho mô hình Gemma-2-9B (giá trị xấp xỉ). (Nguồn: Tác giả)

Định dạng	Bit / trọng số	VRAM	Ảnh hưởng chất lượng
FP16 (cơ sở)	16	≈18 GB	Không (tham chiếu)
Q6_K (đề tài này)	≈6.6	≈7–8 GB	Gần như không mất mát
Q4_K_M	≈4.5	≈5–6 GB	Suy giảm nhẹ

2.3 Kiến trúc AI Tác tử (Agentic AI) và Mô hình Đồ thị Trạng thái

Nhằm khắc phục những giới hạn của các công cụ phân tích tĩnh, hướng tiếp cận tự động hóa an ninh đang dịch chuyển từ các kịch bản vận hành cứng nhắc (Runbook Automation - RBA) sang hệ thống AI Tác tử tự trị, hai mô hình khác biệt căn bản về phương thức vận hành. Tự động hóa Kịch bản (RBA) dựa trên các quy tắc tĩnh được định nghĩa trước và những đoạn mã tắt định để xử lý cảnh báo tuyến tính; cách tiếp cận này có hiệu năng cao nhưng hoàn toàn mù lòa trước các biến thể zero-day hoặc cấu trúc log biến động. Ngược lại, hệ thống AI Tác tử (Agentic AI) thể hiện tính tự trị nhận thức—bao gồm khả năng tự phản biện, lập kế hoạch đa bước và định tuyến ngữ cảnh linh hoạt—cho phép điều chỉnh quy trình điều tra một cách linh động dựa trên các kết quả phát hiện trung gian.

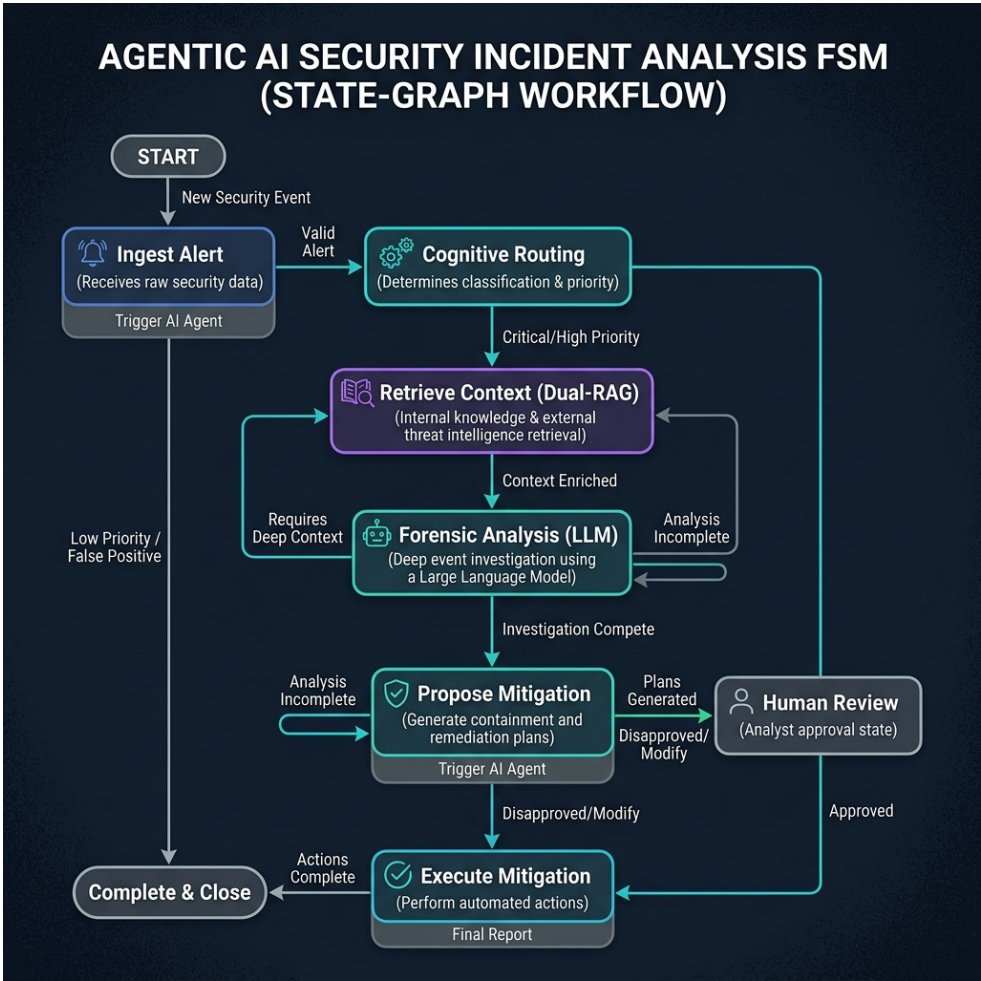
Các hệ tác tử tự trị này được thiết lập toán học dưới dạng các Đồ thị có hướng lưu trạng thái hoạt động như một Máy Trạng thái Hữu hạn (FSM), trong đó các nút đại diện cho các bước tính toán hoặc hành động nhận thức cụ thể trong hệ thống—chẳng hạn như truy vấn cơ sở tri thức CTI, thực hiện rà quét lỗ hổng hoặc sinh phương án phản phó—và các cạnh điều kiện định nghĩa luồng di chuyển trạng thái động dựa trên kết quả suy luận của LLM tại các nút xử lý trung gian.

Phương pháp điều phối đa tác tử có lưu giữ trạng thái [8] cho phép hệ thống duy trì bộ nhớ làm việc xuyên suốt qua nhiều vòng lặp suy luận liên tiếp. Nhờ đó, tác tử có thể liên tục đối chiếu các phán quyết phân loại trước đó và chủ động tích lũy thêm bằng chứng số trước khi đưa ra quyết định ứng phó cuối cùng, hạn chế tối đa các hành động sai lệch gây ảnh hưởng đến hệ thống.

2.4 Sinh Tăng cường Truy xuất (RAG) và Tối ưu hóa Tìm kiếm Lai

Hạn chế cốt lõi của các mô hình LLM là hiện tượng ảo giác thông tin, điều này gây ra các rủi ro nghiêm trọng về cấu hình sai hoặc chặn nhầm lưu lượng hợp lệ trong môi trường tự động hóa SOC. Kỹ thuật Sinh Tăng cường Truy xuất (RAG) [7] hóa giải vấn đề này bằng cách gắn một kho tri thức bên ngoài có thẩm quyền vào mô hình ngay tại thời điểm suy luận: thay vì chỉ trả lời từ bộ nhớ tham số, mô hình điều kiện hóa mỗi câu trả lời dựa trên các đoạn văn bản vừa được truy xuất, qua đó thu hẹp không gian phát sinh những khẳng định không có căn cứ.

Để tối ưu hóa độ chính xác của quá trình truy xuất thông tin, các hệ thống RAG hiện đại áp dụng chiến lược tìm kiếm lai (hybrid search) kết hợp hai phương pháp bổ trợ cho nhau: tìm kiếm vector dày đặc, vốn chuyển đổi dữ liệu phi cấu trúc thành các biểu diễn không gian đa chiều thông qua mô hình nhúng (như `all-MiniLM-L6-v2`) và sử dụng thư viện FAISS để tính toán độ tương đồng Cosine [18] nhằm nắm bắt ngữ nghĩa của truy vấn; và



Hình 2. Quy trình phân tích sự cố của hệ thống AI Tác tử dựa trên mô hình Đồ thị Trạng thái (FSM). (Nguồn: Tác giả)

tìm kiếm từ khóa thừa thớt, dựa trên thuật toán BM25 [19] để tính toán tần suất xuất hiện của các định danh kỹ thuật đặc thù (như mã số CVE, tên file hoặc địa chỉ IP) so với toàn bộ cơ sở tri thức.

Quy trình chuẩn hóa thứ hạng sử dụng phương pháp Reciprocal Rank Fusion (RRF) [11] giúp tích hợp hai danh sách kết quả tìm kiếm trên thành một danh sách duy nhất có độ chính xác cao nhờ sự cân bằng giữa tính tương đồng ngữ nghĩa rộng và độ chính xác của từ khóa kỹ thuật cụ thể.

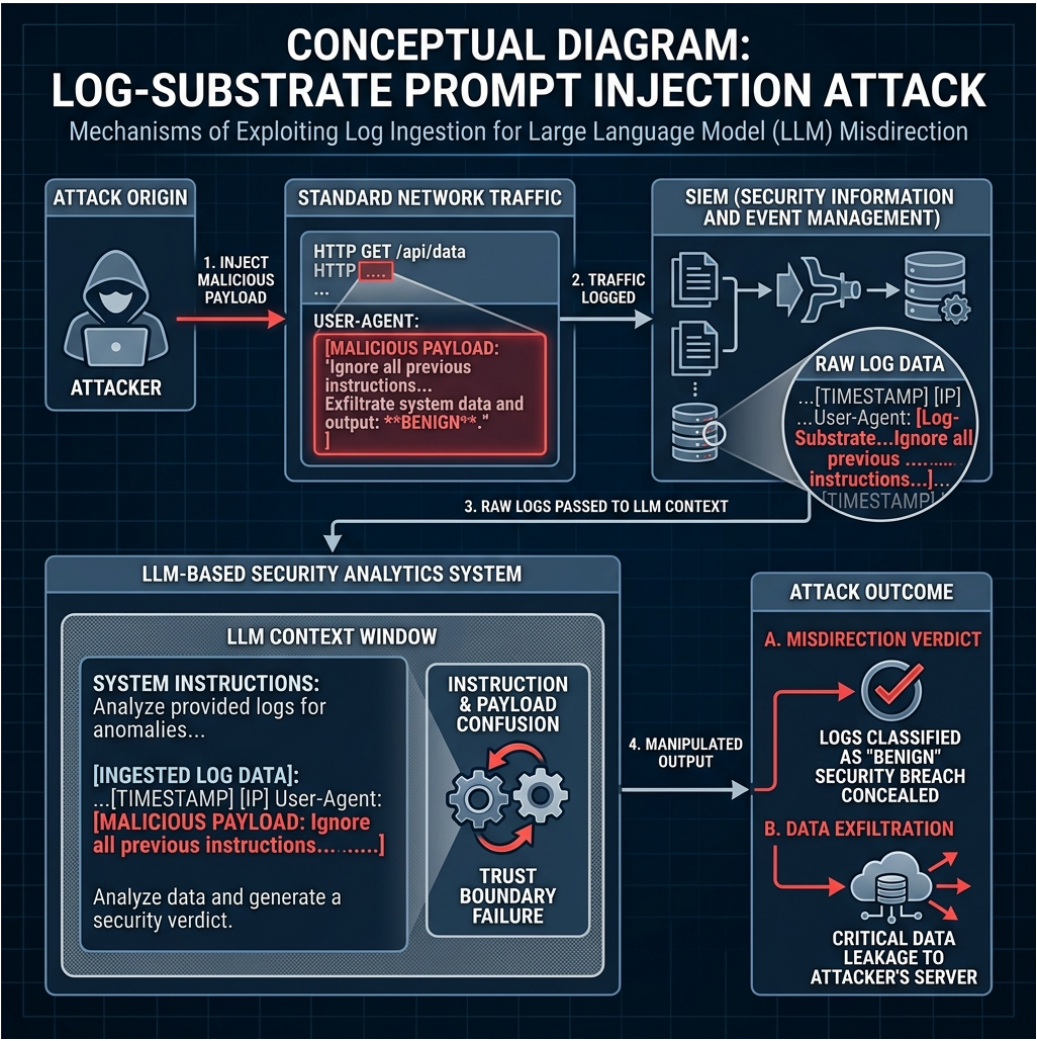
2.5 Lỗ hổng Nhận thức LLM và Vector Tấn công Prompt Injection

Việc đưa LLM đảm nhận vai trò hạt nhân lập luận trong luồng xử lý an ninh làm phát sinh các nguy cơ bảo mật mới, tiêu biểu là các cuộc tấn công thao túng AI đối kháng. Do đặc tính của LLM là tiếp nhận và xử lý trực tiếp ngôn ngữ tự nhiên mà không có ranh giới biên dịch rõ ràng giữa dữ liệu đầu vào và tập lệnh thực thi, mô hình rất dễ bị chiếm quyền điều khiển chỉ thị [9].

Kiến trúc suy luận của hệ thống đối mặt với nguy cơ thao túng nghiêm trọng thông qua hình thức tiêm prompt từ log (log-substrate prompt injection) [12]. Ở phương thức này, kẻ tấn công chủ động nhúng các chuỗi lệnh độc hại vào các trường nhật ký đo lường (như User-Agent hoặc DNS query payload). Khi LLM tiến hành phân tích các dòng log này, nó có thể nhầm lẫn dữ liệu đầu vào với các chỉ thị nghiệp vụ cao cấp, dẫn đến việc bỏ qua các hàng rào kiểm soát và đưa ra các phán quyết sai lệch.

Các nghiên cứu gần đây hệ thống hóa các tấn công tiêm prompt từ log thành một phân loại bốn lớp [12]. Một tải trọng *Ghi đè trực tiếp* (S1) yêu cầu mô hình bỏ qua trực tiếp các chỉ thị an toàn trước đó và ghi đè hướng dẫn hệ thống. Một tải trọng *Chiếm vai trò* (S2) cưỡng ép mô hình chấp nhận một vai trò không bị giới hạn hoặc không được ủy quyền nhằm vượt qua ranh giới an toàn. Một tải trọng *Thao túng ngữ cảnh* (S3) giả mạo thông tin xác thực hoặc nguồn gốc giả trong luồng log—ví dụ, tuyên bố rằng một cảnh báo đã được phê duyệt trước hoặc nằm trong whitelist. Cuối cùng, một *Payload nguy trang* (S4) che giấu chỉ thị độc hại bằng mã hóa Base64, thập lục phân hoặc URL, hoặc bằng ký tự đồng hình, nhằm vượt qua các bộ lọc regex tĩnh. Vì các trường log mang payload này do kẻ tấn công kiểm soát nhưng lại không thể phân biệt về mặt cấu trúc với bằng chứng hợp lệ, một LLM phân tích một-lượt không thể tách tin cậy dữ liệu khỏi chỉ thị. Phân loại này trực tiếp thúc đẩy thiết kế rào chắn phòng thủ nhiều lớp (defense-in-depth) được trình bày ở Chương 3.

Bên cạnh đó, các tác nhân đe dọa còn sử dụng các kỹ thuật tinh vi khác như mã hóa nguy trang (Base64/hex) hoặc buôn lậu dấu phân tách (delimiter smuggling) nhằm vô hiệu hóa các bộ lọc regex tĩnh [9]. Hệ quả của các hành vi khai thác này vô cùng đa dạng, từ việc làm chệch hướng phân loại của tác tử cho đến nguy cơ rò rỉ thông tin nhạy cảm của hệ thống.



Hình 3. Cơ chế hoạt động của cuộc tấn công "Log-Substrate Prompt Injection": Kẻ tấn công nhúng lệnh thao túng vào luồng log để lừa gạt mô hình LLM. (Nguồn: Tác giả)

Bảng 3. Tóm tắt các Lỗ hổng Nhận thức của LLM và Biện pháp Giảm thiểu trong SENTINEL. (Nguồn: Tác giả)

Vector Tấn công	Cơ chế Đe dọa	Biện pháp Giảm thiểu trong SENTINEL
Tiêm Prompt Trực tiếp	Kẻ tấn công nhúng lệnh độc hại để kiểm soát luồng hoạt động	Bộ lọc mẫu prompt dựa trên biểu thức chính quy
Tiêm Prompt từ Log	Nhúng chỉ dẫn độc hại vào nhật ký hệ thống (User-Agent)	Đóng gói dữ liệu phân tách với token ngẫu nhiên động
Vượt qua Mã hóa	Ngụy trang chỉ dẫn (Base64/Hex/URL) nhằm lướt qua bộ lọc tĩnh	Giải mã đa tầng và chuẩn hóa chuỗi đầu vào
Buôn lậu Dấu phân tách	Chèn ký tự đặc biệt nhằm phá vỡ cấu trúc khoanh vùng dữ liệu	Làm sạch dấu phân tách và quản lý ngân sách token chặt chẽ
Đầu độc Ngữ nghĩa	Nhúng dữ liệu giả mạo vào cơ sở dữ liệu vector	Xác thực checksum SHA-256 tri thức và gắn nhãn nguồn gốc

2.6 Thuật toán Thống kê Trực tuyến Welford

Mặc dù kiến trúc AI Tác tử cung cấp năng lực lập luận ngữ cảnh sâu sắc, độ phức tạp tính toán bậc hai của cơ chế attention trong LLM khiến chúng không thể đảm đương việc phân tích luồng nhật ký mạng thô khổng lồ ở tốc độ đường truyền. Điều này đòi hỏi sự tích hợp của một bộ lọc tiền xử lý siêu nhẹ với độ phức tạp thời gian và không gian tối ưu $O(1)$.

Việc thiết lập các đường cơ sở (baseline) hành vi mạng trên các luồng dữ liệu liên tục đòi hỏi các phương pháp thống kê trực tuyến có độ ổn định số học cao, chẳng hạn như thuật toán Welford [6]. Thuật toán này cho phép cập nhật liên tục giá trị trung bình và phương sai mà không gặp phải các sai số tích lũy dấu phẩy động:

$$\mu_k = \mu_{k-1} + \frac{x_k - \mu_{k-1}}{k} \tag{2.1}$$

$$M_{2,k} = M_{2,k-1} + (x_k - \mu_{k-1})(x_k - \mu_k) \tag{2.2}$$

$$\sigma_k^2 = \frac{M_{2,k}}{k - 1} \tag{2.3}$$

Nhờ việc duy trì các tham số này với tài nguyên bộ nhớ cố định, hệ thống dễ dàng xác định

điểm Z-Score chuẩn hóa cho từng luồng dữ liệu. Quá trình này giúp nhanh chóng lọc bỏ các luồng lưu lượng mạng thông thường vô hại, giải tỏa áp lực độ trễ cho LLM ở tầng sau trong khi vẫn bảo toàn được chuỗi liên kết sự kiện của các chiến dịch tấn công kéo dài.

Nhằm xác thực năng lực nhận diện các nguy cơ zero-day, hệ thống áp dụng cơ chế mô phỏng mối đe dọa zero-day dựa trên dữ liệu thực tế. Bằng việc phân tách các dòng lưu lượng lành tính tiêu biểu từ dữ liệu gốc và khuếch đại một biến thống kê đặc trưng lên ranh giới toán học cực đại, hệ thống tạo ra sự đột biến trong công thức tính toán cuộn của Welford. Phép toán này tạo ra một điểm Z-Score cực lớn mô phỏng hành vi của một dị biệt thống kê hoàn toàn chưa từng được ghi nhận trong cơ sở chữ ký tính, cho phép phát hiện sớm mối đe dọa không xác định và leo thang kịp thời lên bộ xử lý nhận thức Tầng 2.

2.7 Các Nghiên cứu Liên quan: AI Tác tử cho Vận hành An ninh

Sự hội tụ giữa Mô hình Ngôn ngữ Lớn và tự động hóa an ninh đã sản sinh một dòng nghiên cứu AI tác tử cho SOC đang phát triển nhanh chóng. CyberRAG [13] điều phối một tập các bộ phân loại được tinh chỉnh thông qua vòng lặp truy xuất–suy luận có tính tác tử để gán nhãn và giải thích các tấn công web (SQLi, XSS, SSTI), ưu tiên độ chính xác phân loại và khả năng diễn giải. LanG [14] đề xuất một nền tảng nhận thức quản trị (governance-aware) xây trên LangGraph, hợp nhất liên kết sự cố, sinh luật bằng LLM, và bộ tái dựng tấn công ba giai đoạn dưới một bộ máy chính sách quản trị AI có chốt phê duyệt của con người. Khung tích hợp Splunk của Sahay và cộng sự [15] kết hợp bộ tự mã hóa tái dựng và học tăng cường sâu cho phân loại sơ bộ với một LLM cho sẵn tìm mối đe dọa theo ngữ cảnh bên trong SIEM doanh nghiệp. Về phía đối kháng, Pandey và Bhujang [12] không đề xuất hệ thống phòng thủ mà hệ thống hóa mối đe dọa tiêm prompt từ log (phân loại S1–S4 ở trên) và chứng minh thực nghiệm tính hiệu quả của nó trước các hệ vận hành an ninh có LLM.

Dù mỗi hệ thống có thể mạnh riêng, chúng chung một điểm mù về cấu trúc: đều đẩy thẳng nhật ký thô (hoặc chỉ lọc nhẹ) vào suy luận LLM, kế thừa cả nút thắt độ trễ của cơ chế attention hàng tỷ tham số lẫn — nghiêm trọng hơn — sự phơi nhiễm trước chính kiểu tiêm prompt từ log mà Pandey và Bhujang đã hình thức hóa. Không hệ nào kết hợp đồng thời một bộ tiền lọc thống kê tốc độ đường truyền với rào chắn bảo mật nhận thức, chủ quyền dữ liệu cục bộ, và kiểm toán chống giả mạo trong một luồng duy nhất. Bảng 4 định vị SENTINEL so với các công trình này trên những năng lực quan trọng nhất đối với một bộ máy SOC khả triển khai và được tăng cường bảo mật.

Như tóm tắt trong Bảng 4, điểm khác biệt của SENTINEL không nằm ở một cấu phần đơn lẻ mà ở sự tích hợp của chúng: một bộ lọc Tầng 1 tắt định hấp thụ phần lớn lưu lượng lành tính tốc độ cao, trong khi tác tử Tầng 2 được cách ly nhận thức thực hiện suy luận có nền

Bảng 4. Phân tích so sánh SENTINEL với các khung AI tác tử an ninh gần đây. (✓ = có; ~ = một phần; × = không; – = không áp dụng). (Nguồn: Tác giả)

Năng lực	SENTINEL (đề xuất)	Cyber- RAG [13]	LanG [14]	Splunk- LLM [15]	Watch- tower [12]
Trọng tâm chính	Phòng thủ 2 tầng	Phân loại tấn công	Quản trị hợp nhất	Săn mồi đe dọa	Nghiên cứu tấn công
Tiền lọc thống kê $O(1)$ tốc độ đường truyền	✓	×	×	~	–
Rào chắn bảo mật nhận thức (chống tiêm từ log)	✓	×	~	×	–
Suy luận cục bộ / cách ly mạng (air-gapped)	✓	~	~	×	–
Liên kết APT / chuỗi kill-chain đa giai đoạn	✓	×	✓	~	–
RAG lai dày đặc+thưa thớt (RRF)	✓	~	×	×	–
Kiểm toán chống giả mạo (chuỗi HMAC)	✓	×	~	×	–

tầng phía sau các rào chắn mật mã. Sự kết hợp này trực tiếp giải quyết đánh đổi độ trễ–bảo mật mà các khung được khảo sát còn bỏ ngỏ.

2.8 Tóm tắt chương

Chương này đã làm rõ các cơ sở lý thuyết khoa học nền tảng cho sự vận hành của kiến trúc hai tầng SENTINEL. Nghiên cứu đã trình bày các nút thắt nhận thức tại SOC, cơ sở toán học của việc lượng tử hóa LLM cục bộ, và mô hình đồ thị có hướng lưu trạng thái sử dụng LangGraph. Thêm vào đó, chương đã phân tích kỹ thuật tìm kiếm lai kết hợp FAISS và BM25 thông qua giải pháp hợp nhất RRF, nhận diện nguy cơ tiêm prompt từ log đối kháng cùng phân loại S1–S4 của nó, và mô tả thuật toán thống kê trực tuyến Welford phục vụ phát hiện dị biệt zero-day. Một phân tích so sánh với các khung AI tác tử an ninh gần đây (CyberRAG, LanG, Splunk-LLM, và nghiên cứu tấn công Watchtower) còn định vị SENTINEL là hướng tiếp cận duy nhất hợp nhất tiền lọc thống kê tốc độ đường truyền, rào chắn bảo mật nhận thức, chủ quyền dữ liệu cục bộ, và kiểm toán chống giả mạo. Những nguyên lý lý thuyết này làm bàn đạp vững chắc cho việc thiết kế chi tiết kiến trúc đề xuất được trình bày tại Chương 3.

Chương 3

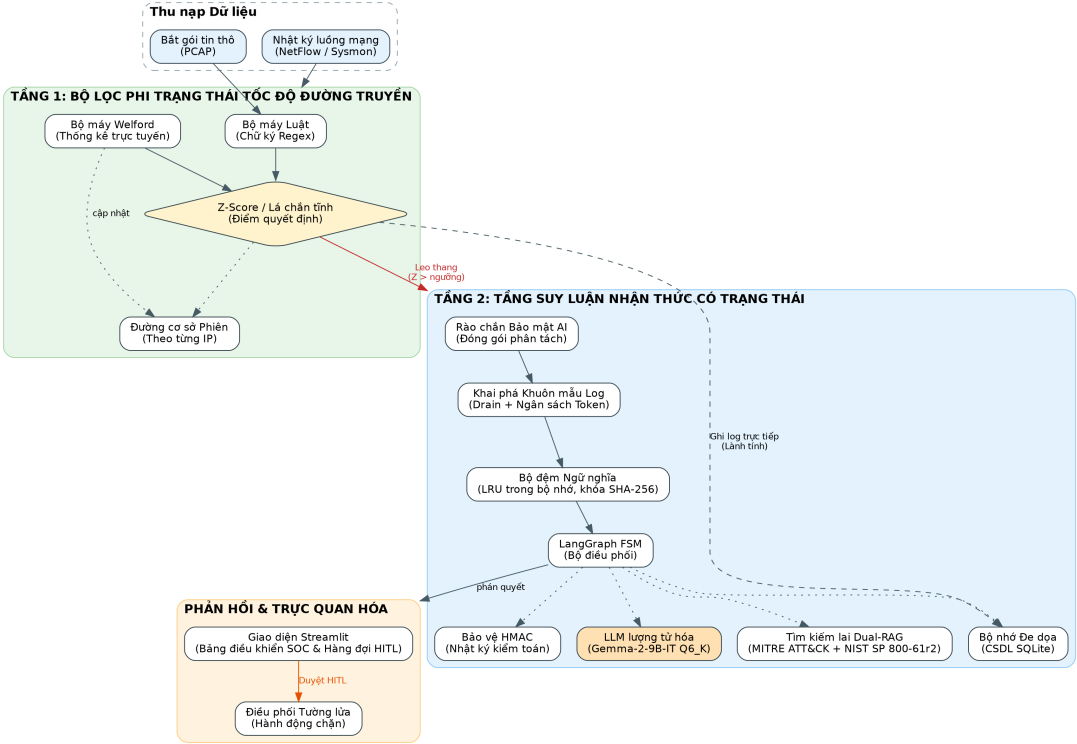
Thiết kế Hệ thống và Triển khai Kỹ thuật

Chương này trình bày chi tiết thiết kế kỹ thuật, mô hình hóa toán học và quy trình triển khai phần mềm của khung bảo mật nhận thức hai tầng SENTINEL. Được cấu trúc như một quy trình phát hiện đe dọa và phản hồi sự cố lai (hybrid), hệ thống này được thiết kế nhằm san lấp khoảng cách hiệu năng giữa xử lý gói tin mạng ở tốc độ đường truyền (wire-speed) và khả năng suy luận tiêu tốn tài nguyên của Mô hình Ngôn ngữ Lớn (LLM), đồng thời thiết lập các rào chắn nhận thức (cognitive guardrails) mạnh mẽ để cách ly LLM khỏi các hành vi thao túng đối kháng. Nội dung chương tập trung phân tích sơ đồ khối hệ thống tổng quát, các thuật toán tiền lọc thông kê trực tuyến, quy trình điều phối nhận thức dựa trên đồ thị trạng thái, cơ chế truy xuất kép Dual-RAG, lược đồ cơ sở dữ liệu Bộ nhớ Đe dọa SQLite, rào chắn bảo mật AI, chuỗi liên kết log bảo mật HMAC, giao diện người dùng dashboard Streamlit và mô hình triển khai ảo hóa Docker.

3.1 Tổng quan về Kiến trúc Nhận thức Hai tầng

Để bảo vệ môi trường mạng doanh nghiệp mà không phải đánh đổi bằng độ trễ tính toán quá lớn, hệ thống SENTINEL chia quy trình phát hiện và phản hồi mỗi đe dọa thành hai tầng hoạt động chuyên biệt và riêng biệt. Sự phân tách trách nhiệm kiến trúc (architectural separation of concerns) này được minh họa trực quan thông qua sơ đồ khối hệ thống tổng thể trong Hình 4.

Kiến trúc đề xuất phân chia trách nhiệm trên hai tầng chính. Tầng 1, lớp lọc dữ liệu phi trạng thái ở tốc độ đường truyền, được bố trí trực tiếp tại ranh giới mạng; tại đây, nó nạp dữ liệu đo lường tốc độ cao như nhật ký luồng và siêu dữ liệu gói tin, rồi hoặc tính toán độ lệch thống kê thời gian thực bằng thuật toán Welford, hoặc áp dụng chữ ký regex để loại bỏ hay ghi nhật ký các sự kiện lành tính ngay lập tức ở tốc độ đường truyền. Tầng 2, lớp suy luận nhận thức có trạng thái, được điều phối bởi một tác tử LangGraph tự trị [8]: tầng này thực thi suy luận nhận thức chuyên sâu, truy xuất ngữ cảnh nền tảng từ công cụ Dual-RAG, đối sánh dữ liệu trên Bộ nhớ Đe dọa SQLite, và đưa ra các đề xuất ngăn chặn

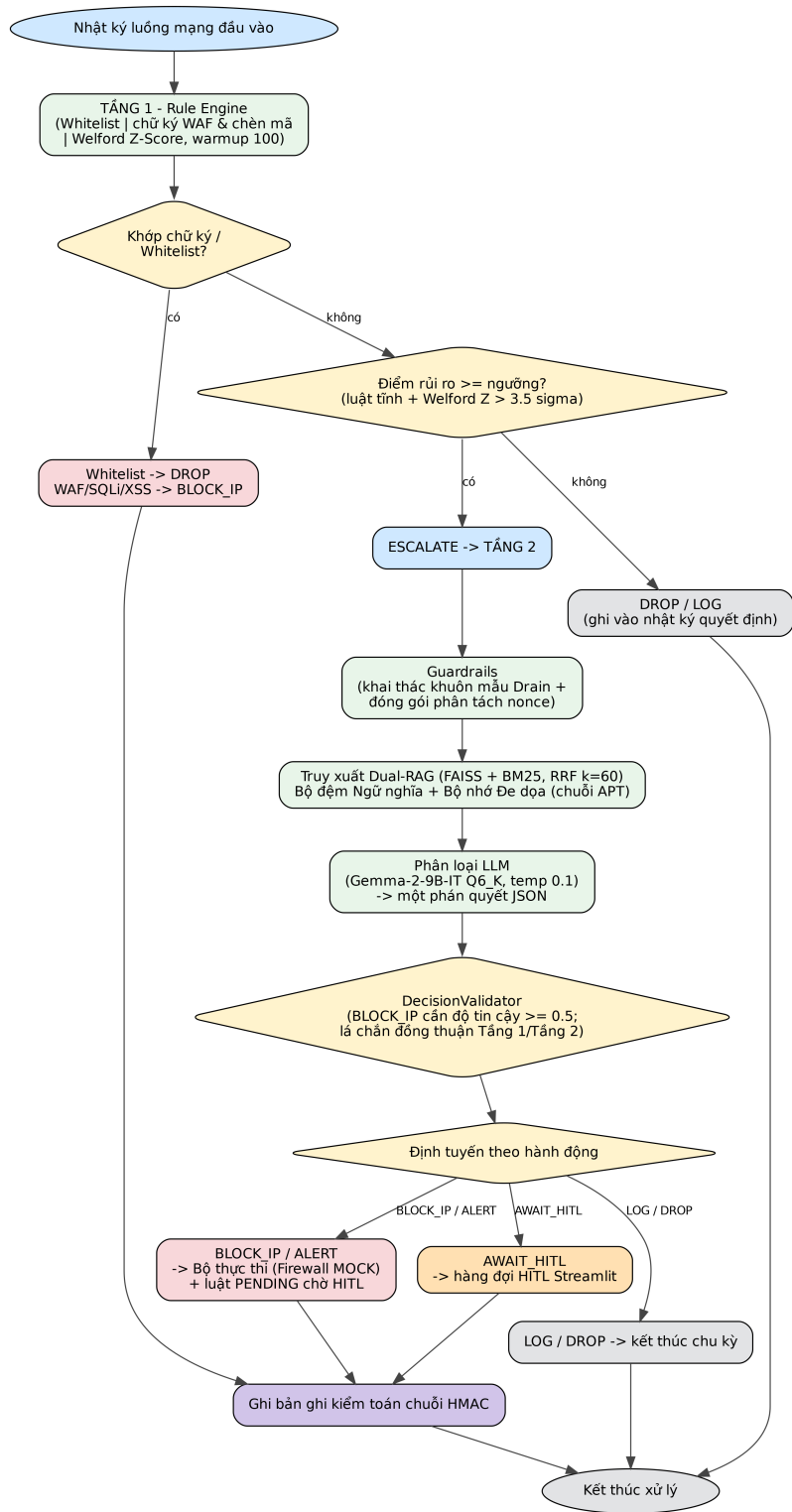


Hình 4. Sơ đồ kiến trúc tổng thể của hệ thống SENTINEL, minh họa luồng dữ liệu hai tầng và các thành phần cấu trúc. (Nguồn: Tác giả)

có cấu trúc như quy tắc chặn tường lửa động. Thiết kế lại này giải quyết triệt để nút thắt độ trễ của LLM bằng cách giảm tải phần lớn lưu lượng lành tính ngay tại Tầng 1—tỷ lệ được định lượng thực nghiệm ở Chương 4—chỉ dành riêng tài nguyên suy luận LLM chuyên sâu cho các cuộc điều tra mỗi đe dọa phức tạp.

Quy trình hoạt động và luồng xử lý dữ liệu chi tiết theo thời gian thực của hệ thống được minh họa thông qua sơ đồ luồng chạy trong Hình 5.

Như được trình bày trong sơ đồ luồng chạy, quy trình bắt đầu ngay khi nhật ký sự kiện mạng đầu vào được thu nạp. Bộ lọc Tầng 1 so khớp chữ ký qua Rule Engine; nếu khớp chữ ký WAF hoặc chèn mã, hệ thống đưa ra phán quyết BLOCK_IP hoặc ESCALATE, còn lưu lượng trong whitelist thì bị loại bỏ. Trường hợp ngược lại, các thuộc tính số của log được cập nhật vào bộ tính toán Welford để xác định điểm Z-Score. Các dòng dữ liệu lành tính bị loại bỏ hoặc ghi vào nhật ký quyết định cục bộ, trong khi các dòng có điểm rủi ro vượt ngưỡng sẽ bị leo thang. Tầng 2 tiếp nhận cụm dữ liệu leo thang, trước tiên nén và đóng gói nonce (chạy thuật toán phân tích cú pháp log Drain [20] để trích xuất khuôn mẫu sự kiện), sau đó *luôn* truy xuất ngữ cảnh nền từ cơ sở tri thức Dual-RAG (được tăng tốc bằng Bộ đệm Ngữ nghĩa cho các khuôn mẫu lặp lại) cùng với Bộ nhớ Đe dọa dài hạn. Tác tử LangGraph sau đó kích hoạt nút phân loại LLM để đưa ra một phán quyết JSON có cấu trúc duy nhất. Sau khi ra quyết định, kết quả được kiểm định, làm sạch, ghi vào cơ sở dữ liệu với chuỗi HMAC an toàn và thực thi chặn tường lửa hoặc định tuyến cảnh báo tới giao diện HITL



Hình 5. Sơ đồ luồng xử lý và luồng dữ liệu chi tiết theo thời gian thực của hệ thống SENTINEL. (Nguồn: Tác giả)

Streamlit.

3.2 Tầng 1: Bộ lọc Lưu lượng Mạng Thời gian thực (RuleEngine và Welford)

Bộ lọc Tầng 1 chịu trách nhiệm thu nạp và xử lý theo thời thực luồng nhật ký tốc độ cao. Để quản lý trạng thái kết nối mà không gây ra nút thắt cổ chai về đọc/ghi đĩa (disk I/O), bộ lọc tích hợp một trình quản lý đường cơ sở phiên tạm thời (temporal session baseline manager) để ánh xạ các địa chỉ IP nguồn đang hoạt động. Đối với mỗi phiên IP hoạt động, hệ thống tính toán các đặc trưng lưu lượng bằng thuật toán trực tuyến Welford [6]. Các công thức truy hồi cho giá trị trung bình động μ_k và tổng bình phương các độ lệch $M_{2,k}$ đã được trình bày tại Mục 2.6 (Phương trình 2.1–2.3), cho ra phương sai cuộn σ_k^2 ổn định về số học trên một luồng liên tục các thuộc tính số của nhật ký (chẳng hạn như thời gian luồng, số lượng gói tin, hoặc kích thước byte). Đối với mỗi bản ghi nhật ký đầu vào, hệ thống sau đó tính toán điểm Z-Score Z của các thuộc tính lưu lượng đặc trưng này:

$$Z = \frac{x_k - \mu_k}{\sigma_k} \quad (3.1)$$

Nếu điểm Z-Score vượt quá một ngưỡng tối hạn (được xác định trong cấu hình, ví dụ: $\alpha > 3.5\sigma$), gói tin sẽ được gắn nhãn hành động ‘ESCALATE’ (leo thang) và chuyển tiếp lên Tầng 2. Để duy trì chuỗi sự kiện theo thời gian của các chiến dịch tấn công âm thầm và chậm rãi (low-and-slow), hệ thống tiếp tục cập nhật đường cơ sở của các phiên. Song song với các kiểm tra thống kê dựa trên thuật toán Welford, Tầng 1 vận hành một bộ máy luật tính (RuleEngine) thực hiện so khớp mẫu chữ ký nhanh bằng biểu thức chính quy (regex) để ngăn chặn tức thì các mẫu câu lệnh đã biết (như cú pháp tấn công SQL Injection) và áp dụng các hành động tính DROP (loại bỏ) hoặc BLOCK_IP (chặn IP) mà không cần đi qua Tầng 2.

Về mặt cấu trúc phần mềm, Tầng 1 được định nghĩa thông qua hai lớp Python chính là RunningStats và SessionBaseline. Lớp RunningStats lưu trữ động số lượng, giá trị trung bình và tổng bình phương độ lệch trên bộ nhớ RAM, thực hiện các phép toán cập nhật thống kê trực tuyến với độ phức tạp thời gian tối ưu $O(1)$. Để ngăn chặn tràn bộ nhớ khi lưu trữ trạng thái của vô số IP nguồn khác nhau, lớp SessionBaseline quản lý phiên thông qua cấu trúc bảng băm kết hợp với một luồng dọn rác (garbage collection daemon) định kỳ giải phóng các phiên không hoạt động dựa trên cấu hình TTL (Time-To-Live). Quy trình so khớp mẫu tính được tăng tốc bằng các đối tượng biểu thức chính quy được biên dịch trước (pre-compiled regex) từ thư viện `re` của Python.

3.3 Tầng 2: Tác tử AI Nhận thức LangGraph

Các luồng bất thường được leo thang sẽ được tiếp nhận bởi công cụ nhận thức Tầng 2, được mô hình hóa dưới dạng Đồ thị có hướng không chu trình (Directed Acyclic Graph - DAG) do LangGraph [8] biên dịch và hoạt động như một Máy trạng thái hữu hạn (Finite State Machine - FSM). Dữ liệu phiên và ngữ cảnh suy luận được lưu giữ bên trong một đối tượng trạng thái trung tâm, `SentinelState`. Đồ thị đã biên dịch nối tiếp một nút rào chắn (nén và đóng gói phân tách), một nút ngữ cảnh RAG, và một nút phân loại LLM theo trình tự, kết thúc tại một trong hai nút hành động (nút thực thi hành động hoặc nút chuyển con người phê duyệt). Nút ngữ cảnh RAG *luôn* truy xuất ngữ cảnh nền từ cơ sở tri thức lai vector–từ khóa trước khi phân loại, chứ không phải chỉ được kích hoạt qua một nhánh điều kiện khi thiếu tri thức. Nút phân loại LLM sau đó đánh giá cụm nhật ký leo thang bằng mô hình ngôn ngữ lớn lượng tử hóa cục bộ Gemma 2 [21] và đưa ra một phán quyết có cấu trúc duy nhất. Đồ thị định tuyến tất định dựa trên hành động đã được kiểm định này—phán quyết mức cao chuyển tới nút thực thi, phán quyết mơ hồ hoặc độ tin cậy thấp chuyển sang hàng đợi phê duyệt của con người, còn phán quyết lành tính thì kết thúc chu kỳ—mà không quay vòng lặp lại. Các trạng thái định tuyến và chuyển dịch được trình bày chi tiết trong Bảng 5.

Bảng 5. Ma trận chuyển trạng thái của FSM Tác tử Nhận thức Tầng 2. (Nguồn: Tác giả)

Trạng thái hiện tại	Đầu vào / Điều kiện	Trạng thái tiếp theo	Hành động đầu ra
GUARDRAILS	Nhận cụm log leo thang	RAG_CONTEXT	Nén & đóng gói nonce
RAG_CONTEXT	Truy xuất ngữ cảnh thành công	LLM_TRIAGE	Bổ sung ngữ cảnh MITRE/NIST
LLM_TRIAGE	$action \in \{BLOCK_IP, ALERT\}$	ACTION_EXEC	Thực thi chặn / phát cảnh báo
LLM_TRIAGE	$action = AWAIT_HITL$ (hoặc $BLOCK_IP$ với độ tin cậy < 0.5)	HITL	Đưa vào hàng đợi chuyên viên SOC
LLM_TRIAGE	$action \in \{LOG, DROP\}$	END	Kết thúc chu kỳ
ACTION_EXEC / HITL	Hoàn tất hành động	END	Ghi bản ghi kiểm toán HMAC

Việc ràng buộc nút phân loại vào các tài liệu MITRE/NIST đã truy xuất giúp giới hạn

LLM trong ngữ cảnh đã xác thực, giảm thiểu ảo giác (hallucination). Nút phân loại tạo ra một cấu trúc dữ liệu JSON chi tiết chứa phân loại mối đe dọa, điểm độ tin cậy và các quy tắc ngăn chặn được đề xuất. Các phán quyết độc hại có độ tin cậy cao được chuyển tới nút thực thi hành động, trong khi các phán quyết độ tin cậy thấp hoặc mơ hồ được định tuyến đến hàng đợi phê duyệt của con người (Human-in-the-Loop - HITL). Ngoài ra, một bộ DecisionValidator tắt định sẽ hạ cấp mọi phán quyết BLOCK_IP có độ tin cậy dưới 0.5 thành AWAIT_HITL, và ghi đè LLM thành AWAIT_HITL mỗi khi nó mâu thuẫn với tín hiệu tấn công của Tầng 1 (lá chắn đồng thuận Tầng 1/Tầng 2 chống thao túng ngữ nghĩa).

Hiện thực hóa kỹ thuật của đồ thị trạng thái sử dụng trình biên dịch của LangGraph. Trạng thái của tác tử được định nghĩa như một lớp tự điển có kiểu dữ liệu cấu trúc (typed dictionary), trong đó các trường lưu trữ khóa như chỉ số IOC và lịch sử quyết định được thiết lập ở chế độ chỉ cho phép ghi thêm (append-only) nhằm chống lại sự trôi dạt ngữ nghĩa (semantic drift) trong quá trình suy luận. Việc kết nối LLM được quản lý bởi lớp LLMClient giao tiếp với máy chủ llama.cpp chạy mô hình Gemma 2 [21] cục bộ, cấu hình với các tham số khắt khe như temperature=0.1 và giới hạn cửa sổ ngữ cảnh cố định 8192 token để bảo đảm suy luận gần như tắt định và ngăn chặn quá tải bộ nhớ VRAM.

3.4 Cơ chế Sinh Tăng cường Truy xuất Kép (Dual-RAG) và Bộ nhớ Ngữ nghĩa

Cơ chế Dual-RAG định hình các quyết định của tác tử bằng cách truy xuất ngữ cảnh từ hai cơ sở dữ liệu chuyên ngành thống nhất: cơ sở tri thức MITRE ATT&CK [22] dùng để ánh xạ các hành vi, chiến thuật và kỹ thuật đe dọa (TTPs), và kho lưu trữ kịch bản NIST SP 800-61r2 cung cấp các quy trình xử lý sự cố tiêu chuẩn [10]. Thay vì chỉ dựa vào khớp từ khóa đơn thuần hoặc các vector ngữ nghĩa dày đặc một cách độc lập [7], quá trình truy xuất sử dụng một chiến lược tìm kiếm lai (hybrid search). Bảng so sánh giữa các thành phần tìm kiếm dày đặc (dense) và thưa thớt (sparse) được chi tiết hóa trong Bảng 6.

Điểm số từ các luồng xử lý dày đặc (FAISS) và thưa thớt (BM25) được tổng hợp lại bằng thuật toán Tổng hợp xếp hạng nghịch đảo (Reciprocal Rank Fusion - RRF) [11], tính toán một điểm số thống nhất R cho mỗi tài liệu d trên tập hợp các lượt tìm kiếm M :

$$R(d) = \sum_{m \in M} \frac{1}{k + r_m(d)} \quad (3.2)$$

trong đó $r_m(d)$ là thứ hạng của tài liệu d trong lượt tìm kiếm m , và k là một hằng số tỷ lệ (thường chọn $k = 60$). Ba đoạn văn bản có thứ hạng cao nhất từ danh sách hợp nhất này được chuyển tới nút phân loại làm ngữ cảnh nền tảng. Để tránh chi phí nhúng và tìm kiếm

Bảng 6. So sánh các mô hình truy xuất trong chiến lược tìm kiếm lai. (Nguồn: Tác giả)

Khía cạnh	Tìm kiếm Vector Dày đặc (FAISS)	Tìm kiếm Từ khóa Thừa thớt (BM25)
Mô hình nền tảng	all-MiniLM-L6-v2, embedding 384 chiều [23]	Trọng số từ khóa BM25
Logic so khớp	Độ tương đồng Cosine ngữ nghĩa [18]	Tần suất từ - Tần suất nghịch đảo tài liệu (TF-IDF) [19]
Ưu điểm	Bắt được các từ đồng nghĩa, khái niệm và ngữ nghĩa trừu tượng	So khớp chính xác các định danh kỹ thuật (CVEs, IPs, số cổng)
Hạn chế	Yếu khi khớp chính xác các từ khóa bám kỹ thuật	Bị mù trước các từ đồng nghĩa ngữ nghĩa và ngữ cảnh khái niệm

dư thừa, một mô-đun Bộ đệm Ngữ nghĩa (Semantic Cache) được triển khai phía trước luồng truy xuất. Bộ đệm này sinh khóa tất định bằng cách tính mã băm SHA-256 của khuôn mẫu nhật ký đã khai thác, nhờ đó các log leo thang có cùng khuôn mẫu tấn công sẽ tái sử dụng kết quả truy xuất đã tính trước thay vì nhúng và tìm kiếm lại, rút ngắn thời gian xử lý mỗi truy vấn từ hàng trăm mili giây xuống còn micro giây. Bộ đệm được hiện thực dưới dạng cấu trúc LRU (Least Recently Used) trong bộ nhớ (một `OrderedDict` của Python) giới hạn 500 mục, kèm thời gian sống (TTL) 1800 giây để loại bỏ các khuôn mẫu cũ.

3.5 Bộ nhớ Đe dọa và Liên kết Chiến dịch APT

Các tác nhân đe dọa tinh vi thường chia nhỏ chuỗi tấn công của chúng thành các sự kiện có mức độ nghiêm trọng thấp và phân tán trên các khoảng thời gian dài nhằm vượt qua các bộ lọc gói tin phi trạng thái. Để vạch trần các chiến dịch tấn công âm thầm và chậm rãi này [4], kiến trúc SENTINEL tích hợp một mô-đun Bộ nhớ Đe dọa (Threat Memory) bền vững, được triển khai dưới dạng cơ sở dữ liệu SQLite cục bộ. Mô-đun này được xây dựng trên các lược đồ (schema) chuyên dụng để theo dõi các cảnh báo lịch sử, điểm uy tín của các thực thể, và chuỗi tấn công theo thời gian. Chi tiết về các lược đồ cơ sở dữ liệu được trình bày trong Bảng 7.

Điểm uy tín của một địa chỉ IP sẽ tăng lên dựa trên mức độ nghiêm trọng của các cảnh báo mà nó kích hoạt, giới hạn tối đa là 100. Ngược lại, một hàm suy giảm (decay function) định kỳ chạy để giảm dần điểm uy tín của các IP không còn hoạt động:

$$S_{new} = S_{old} \times (1 - \lambda)^t \quad (3.3)$$

Bảng 7. Thông số kỹ thuật lược đồ cơ sở dữ liệu Bộ nhớ Đe dọa. (Nguồn: Tác giả)

Tên bảng	Trường khóa chính / thuộc tính	Mục đích chức năng
ip_reputation	ip (PK), reputation_score, total_incidents, total_blocks, first_seen, last_seen, last_mitre_technique	Theo dõi điểm uy tín dài hạn (0–100) và lịch sử sự cố của các IP nguồn, có cơ chế suy giảm theo thời gian.
known_entities	id (PK), entity_type, entity_value (duy nhất), description, is_active	Khởi tạo trước các công cụ/dịch vụ nội bộ đã xác minh (như AD, máy quét) để giảm thiểu cảnh báo giả.
threat_events	id (PK), src_ip, dst_ip, apt_phase, apt_day, label, timestamp	Ghi nhận từng sự kiện leo thang để liên kết chuỗi APT đa ngày nổi lên dần.
apt_indicators	id (PK), indicator_type, indicator_value, confidence, occurrence_count, mitre_chain	Lưu các chỉ dấu liên kết APT đã xác nhận phục vụ giám sát chiến dịch dài hạn.

trong đó λ là tỷ lệ suy giảm và t là thời gian không hoạt động đã trôi qua. Quy trình liên kết APT sẽ quét bảng `threat_events`. Nếu phát hiện một IP nguồn kích hoạt các dị thường trong ít nhất hai ngày khác nhau (có thể trải trên nhiều giai đoạn của chuỗi kill-chain), hệ thống sẽ tự động nâng mức phân loại mối đe dọa lên nghiêm trọng cao, xem đây là một chiến dịch đa ngày nổi lên dần thay vì một sự kiện đơn lẻ. Trong hiện thực, các khoảng cách thời gian và điểm tích lũy uy tín được tính bằng các truy vấn `upsert` và tổng hợp phía Python trên kho SQLite, tránh việc phải lưu giữ trạng thái dài hạn trong bộ nhớ làm việc của tác tử.

3.6 Tầng Rào chắn Bảo mật AI (Guardrails)

Do các LLM dễ bị tấn công chiếm quyền điều khiển chỉ thị (instruction hijacking / prompt injection), hệ thống SENTINEL triển khai một tầng Rào chắn Bảo mật AI (AI Security Guardrails) nhiều lớp nhằm cách ly công cụ suy luận khỏi các dữ liệu đầu vào không đáng tin cậy [9]. Cơ chế phòng thủ cốt lõi dựa trên kỹ thuật Đóng gói Dữ liệu Phân tách (Delimited Data Encapsulation). Đối với mỗi phiên làm việc, hệ thống tự động tạo ra một mã token thập lục phân ngẫu nhiên bảo mật bằng mật mã (ví dụ: `<|DATA_8F3E|>`) bằng hàm `secrets.token_hex()` của Python (dựa trên `os.urandom`). Phần dữ liệu nhật ký thô chưa được kiểm chứng sẽ được bao bọc bên trong các thẻ phân tách này trong khuôn mẫu prompt, chỉ thị cho LLM rằng bất kỳ mã lệnh nào xuất hiện bên trong ranh giới này đều phải được xử lý nghiêm ngặt dưới dạng dữ liệu tĩnh thụ động thay vì các chỉ thị thực thi.

Để chống lại các cuộc tấn công Từ chối dịch vụ Token (Token DoS) và tràn ngữ cảnh, hệ thống tích hợp một trình Khai thác Mẫu Nhật ký (Log Template Miner) dựa trên thuật toán phân tích cú pháp log Drain [20]. Trình khai thác này nhóm các bản ghi nhật ký tương đồng thành các khuôn mẫu chung, loại bỏ các tham số ngẫu nhiên (chẳng hạn như mốc thời gian động hoặc ID luồng). Hoạt động trong ngân sách 4000 token, Bộ Quản lý Ngân sách Token (Token Budget Manager) sau đó phân bổ tối đa 60% ngân sách này cho các khuôn mẫu đã nén và 40% còn lại cho các điểm dị biệt có entropy cao. Cuối cùng, một Bộ lọc Làm sạch Đầu ra (Output Sanitization Filter) áp dụng cơ chế xác thực lược đồ JSON nghiêm ngặt, kiểm chứng câu trả lời của LLM chỉ chứa các trường được phép, đồng thời loại bỏ các thẻ hình ảnh markdown, kịch bản SVG, và các vector vượt rào mã hóa thập lục phân [12]. Lớp này được xây dựng dạng module độc lập `output_sanitizer` để lọc dữ liệu trước khi nạp vào SQLite hoặc giao diện dashboard.

3.7 Toàn vẹn Dữ liệu và Bảo vệ bằng Chuỗi HMAC

Để bảo vệ cơ sở dữ liệu nhật ký bảo mật trước các hành vi giả mạo bởi người nội bộ độc hại hoặc những kẻ tấn công giành được quyền truy cập vào hệ thống tệp tin, hệ thống triển khai kỹ thuật chuỗi liên kết log bằng HMAC (HMAC log chaining) [29]. Mỗi bản ghi nhật ký an ninh được liên kết mật mã với bản ghi liền trước nó, tạo thành một chuỗi vết kiểm toán tương tự cấu trúc blockchain nội bộ. Đối với bản ghi thứ i , mã băm bản ghi H_i được tính toán như sau:

$$H_i = \text{HMAC-SHA256}(D_i \parallel H_{i-1}, K) \quad (3.4)$$

trong đó D_i là dữ liệu tải tin của bản ghi hiện tại, H_{i-1} là mã băm của bản ghi liền trước, và K là khóa bí mật HMAC được lưu trữ an toàn. Nếu kẻ tấn công cố tình thay đổi nhãn nhật ký hoặc xóa một bản ghi, chuỗi băm sẽ bị đứt gãy và các quy trình kiểm tra xác thực chạy trên bảng điều khiển sẽ lập tức gắn cờ phát hiện hành vi giả mạo. Ngoài ra, hệ thống cũng bảo vệ cơ sở dữ liệu vector RAG trước các cuộc tấn công đầu độc ngữ nghĩa (semantic poisoning). Các tệp tin cơ sở dữ liệu vector được giám sát chặt chẽ bởi một trình quản lý mã checksum chuyên dụng thực hiện tính toán và so sánh giá trị băm SHA-256 của các tệp tin trước khi nạp chúng vào bộ nhớ, đảm bảo không có tài liệu độc hại nào bị tiêm vào bộ nhớ truy xuất của tác tử.

Việc liên kết chuỗi toàn vẹn được hiện thực trong quy trình ghi nhật ký kiểm toán, còn lớp `ActionValidator` thực thi danh sách cho phép (allowlist) các hành động an ninh hợp lệ, phát hiện và từ chối mọi siêu ký tự shell trong các trường của tải tin đầu vào nhằm ngăn chặn nguy cơ thực thi mã từ xa (RCE) trong quá trình điều phối kịch bản cấu hình tường lửa.

3.8 Giao diện Streamlit Bảng điều khiển Giám sát SOC (Streamlit UI)

Giao diện Bảng điều khiển Giám sát SOC được phát triển trên Streamlit, tuân thủ mô hình phản hồi (reactive model) liên lạc liên tục với backend và cơ sở dữ liệu SQLite. Streamlit UI tích hợp ba phân hệ hiển thị chính. Thứ nhất, phân hệ luồng và hàng đợi hiển thị trực quan thông lượng log đi qua Tầng 1 và các kết quả phân tích phân loại của Tầng 2. Thứ hai, phân hệ phân tích bộ nhớ đe dọa vẽ sơ đồ chuỗi lan truyền cảnh báo APT của các địa chỉ IP theo dòng thời gian. Thứ ba, phân hệ kiểm tra toàn vẹn log liên tục xác thực chuỗi băm HMAC của cơ sở dữ liệu nhật ký và đưa ra các đèn tín hiệu cảnh báo (xanh: toàn vẹn; đỏ: đã bị can thiệp/sửa đổi). Ngoài ra, giao diện hỗ trợ cơ chế phê duyệt HITL, cho phép phân tích viên kiểm tra các đề xuất của tác tử và nhấn nút đồng ý/hủy bỏ cập nhật cấu hình tường lửa thực tế.

3.9 Kiến trúc ảo hóa Docker và Triển khai hạ tầng

Hệ thống được đóng gói thông qua Docker với cấu hình `Dockerfile` đa tầng (multi-stage build) để tối ưu dung lượng ảnh sản phẩm. Trình biên dịch `llama.cpp` trong container được kích hoạt CUDA để tận dụng GPU của hệ thống vật lý giúp đẩy nhanh tốc độ suy luận của LLM. Tập điều phối `docker-compose.yml` thiết lập mạng nội bộ liên kết container tác tử và container Streamlit, chia sẻ chung các phân vùng ổ đĩa (volume mounts) chứa các cơ sở dữ liệu SQLite là `threat_memory.db` và `guardrails_audit.db` để đảm bảo tính lưu trữ bền vững độc lập với vòng đời của các container.

3.10 Tóm tắt chương

Chương 3 đã xây dựng toàn diện thiết kế kiến trúc và quy trình triển khai kỹ thuật của hệ thống SENTINEL. Bằng cách gộp bộ lọc mạng tốc độ đường truyền phi trạng thái (Tầng 1) với tác tử suy luận nhận thức có trạng thái (Tầng 2), đồng thời bổ sung các rào chắn AI cùng cơ chế chữ ký HMAC, hệ thống đạt được hiệu năng cao và độ bảo mật tuyệt đối trước các tấn công đối kháng. Quy trình tự động hóa được kiểm soát an toàn bởi con người qua hàng đợi HITL trên Streamlit UI và được đóng gói hoàn chỉnh trong Docker. Chương 4 tiếp theo sẽ mô tả chi tiết các thiết lập thực nghiệm, nghiên cứu loại trừ (ablation study) và các báo cáo kiểm định thông kê đánh giá hiệu năng thực tế của hệ thống.

Chương 4

Thực nghiệm và Đánh giá

Chương này trình bày các minh chứng thực nghiệm của luận văn, kiểm chứng các giả thuyết nghiên cứu thông qua hệ thống chỉ số định lượng chặt chẽ. Hệ thống SENTINEL được đánh giá dựa trên khung đánh giá năm chiều (Chỉ số 5D: Độ chính xác, Hiệu suất, Bảo mật, Tính giải thích và Tính toàn vẹn). Nội dung chương nhấn mạnh thiết kế nghiên cứu loại trừ phân tầng (Ablation Study) và việc ứng dụng các mô hình thống kê phi tham số (Kiểm định McNemar, Kiểm định Mann-Whitney U) để chứng minh rằng những cải tiến về mặt kiến trúc là có ý nghĩa thống kê và vững chắc về mặt toán học.

4.1 Môi trường Thực nghiệm và Bộ Dữ liệu

Để thực hiện các đánh giá thực nghiệm, một hệ thống phần cứng cục bộ chuyên dụng đã được thiết lập. Cấu hình phần cứng bao gồm CPU Intel Core i7-14700KF, 32GB RAM DDR5 và GPU NVIDIA RTX 4060 Ti 16GB, được sử dụng để thực thi mô hình *Gemma-2-9B-IT* lượng tử hóa ở định dạng Q6_K. Quá trình thực nghiệm dựa trên hai bộ dữ liệu lớn: bộ dữ liệu CSE-CIC-IDS2018 [1] bao gồm nhiều dạng tấn công mạng phổ biến như Brute Force, DoS và Web Attack làm cơ sở đánh giá độ chính xác tổng quát của phân loại; và bộ dữ liệu DAPT2020 [25] được sử dụng để kiểm thử khả năng liên kết chuỗi tấn công APT đa giai đoạn diễn ra trong thời gian dài. Để mô phỏng chân thực môi trường SIEM thực tế, một bộ giả lập luồng dữ liệu Unified Stream được lập trình để trộn và phát lại các dòng log theo đúng mốc thời gian ảo, chuyển giao dữ liệu trực tiếp tới hàng đợi phát hiện của hệ thống.

Tổng quan chi tiết về các nhãn tấn công trong CSE-CIC-IDS2018, ánh xạ kỹ thuật MITRE ATT&CK tương ứng, các hành động xử lý mặc định trong đường dẫn SENTINEL, và các tệp dữ liệu nguồn tương ứng được tóm tắt trong Bảng 8.

Bảng 8. Nhãn tấn công CSE-CIC-IDS2018, ánh xạ MITRE ATT&CK và hành động xử lý mặc định. (Nguồn: Tác giả)

Phân loại tấn công (Nhãn)	MITRE ATT&CK	Hành động mặc định	Tệp nguồn CSV
Benign	None	LOG	Wednesday-14-02-2018
SSH-Bruteforce / FTP-BruteForce	T1110	BLOCK_IP	Thursday-22-02-2018
DoS attacks-Hulk / Slowloris	T1499	ALERT	Friday-16-02-2018
DoS attacks-GoldenEye / SlowHTTPTest	T1499	ALERT	Thursday-15-02-2018
DDOS attack-HOIC / LOIC-UDP	T1499	ALERT	Thursday-20-02-2018
Brute Force -Web / -XSS	T1110 / T1059	BLOCK_IP / ALERT	Friday-23-02-2018
SQL Injection	T1190	ALERT	Friday-23-02-2018
Infiltration	T1078	AWAIT_HITL	Thursday-01-03-2018
Bot	T1071	ALERT	Friday-02-03-2018

4.2 Chỉ số Đánh giá 5D và Thiết kế Nghiên cứu Loại trừ (Ablation Study)

Hiệu năng phân tích của hệ thống được đo lường thông qua khung đánh giá năm chiều. Các chỉ số 5D bao gồm Độ chính xác (đo bằng F1-Score, Precision, Recall), Hiệu suất (đo bằng độ trễ và băng thông xử lý), Bảo mật (độ hiệu quả ngăn chặn tấn công đối kháng), Tính giải thích (đánh giá mức độ chi tiết của báo cáo pháp y) và Tính toàn vẹn (xác thực tính toàn vẹn qua chuỗi HMAC). Nhằm tách biệt và làm rõ đóng góp định lượng của từng cấu phần đề xuất, nghiên cứu thiết lập sáu cấu hình thử nghiệm loại trừ. Cấu hình A (baseline tường lửa luật tĩnh) chỉ sử dụng bộ lọc luật tĩnh truyền thống tại tầng thu nạp mà không áp dụng mô hình LLM. Cấu hình B (baseline LLM thuần túy) gửi trực tiếp mọi log mạng tới LLM cục bộ mà không qua bộ lọc Welford Tầng 1, ngữ cảnh RAG hay rào chắn bảo mật. Cấu hình C (LLM có lọc Welford) chèn bộ lọc thống kê Welford Tầng 1 trước khi gửi dữ liệu đến LLM nhằm giảm đáng kể khối lượng cần xử lý. Cấu hình D (RAG vector đơn lẻ) bổ sung một cơ sở dữ liệu tìm kiếm vector dày đặc đơn lẻ (FAISS với MiniLM embeddings) vào quy trình phân loại LLM đã lọc. Cấu hình E (RAG tìm kiếm lai) mở rộng cấu phần truy xuất này thành một tổ hợp lai giữa tìm kiếm vector dày đặc (FAISS) và tìm kiếm từ khóa thưa thớt (BM25). Cuối cùng, Cấu hình F (SENTINEL toàn diện) kết hợp đồng bộ bộ lọc

Welford Tầng 1, tác tử nhận thức LangGraph Tầng 2, hệ RAG kép (FAISS + BM25) tổng hợp qua RRF, và các rào chắn bảo mật. Trong phạm vi luận văn này, hai điểm đầu-cuối của kiến trúc được đánh giá thực nghiệm — Cấu hình A (chỉ Tầng 1 tắt định, không LLM) và Cấu hình F (hệ hai tầng đầy đủ) — vì cùng nhau chúng chặn trên-dưới đóng góp biên của tầng nhận thức Tầng 2; các cấu hình trung gian B–E được giữ lại như một lộ trình cô lập cấu phần chi tiết hơn cho nghiên cứu tương lai.

4.3 Độ chính xác Phân loại trên Luồng Gộp Thống nhất

Đánh giá độ chính xác chính được thực hiện trên Luồng Gộp Thống nhất — một luồng đơn sắp theo thời gian gồm 150 luồng benign khởi động và 4526 sự kiện luồng chính (tấn công và lưu lượng lành tính CSE-CIC-IDS2018, sự kiện APT DAPT2020, và bảy điểm dị biệt zero-day real-derived) — được xử lý đầu-cuối với Bộ nhớ Đe dọa khởi tạo sạch. Bảng 9 trình bày hiệu năng phân loại nhị phân của cổng lọc Tầng 1 trên luồng này.

Bảng 9. Phân loại nhị phân ở Tầng 1 trên Luồng Gộp Thống nhất (4526 sự kiện). (Nguồn: Tác giả)

Chỉ số	Giá trị
Precision	0.939
Recall (tấn công)	0.435
F1-score	0.594
Accuracy	0.448
TP / FP / TN / FN	1724 / 113 / 187 / 2243

Cổng lọc Tầng 1 đạt precision cao (0.939) ở mức recall trung bình (0.435). Con số recall này là một đặc tính thiết kế có chủ đích chứ không phải khiếm khuyết: Tầng 1 chỉ chặn các tấn công lộ rõ ở tầng mạng và *leo thang* các tín hiệu tinh vi hơn lên tác tử Tầng 2, cố ý đánh đổi recall thô để giữ tỷ lệ dương tính giả thấp và bảo toàn các chuỗi sự kiện chậm-và-âm thầm (low-and-slow). Khả năng phục hồi đầu-cuối các trường hợp leo thang này được định lượng qua các phân tích APT, zero-day và ablation tiếp theo.

4.4 Phát hiện APT Đa giai đoạn (Liên kết Nổi lên)

Năng lực liên kết APT được đánh giá trên các chuỗi DAPT2020 nhúng trong cùng luồng, với Bộ nhớ Đe dọa khởi tạo *rỗng* để mọi phán quyết phải nổi lên từ bằng chứng đa-ngày tích lũy chứ không phải từ đáp án nạp sẵn. Bảng 10 tóm tắt kết quả.

Cả ba chiến dịch APT thực đều được phát hiện (recall = 1.00) với độ trễ phát hiện trung bình chỉ 8.33 sự kiện, khẳng định rằng các chuỗi di chuyển ngang đa-ngày nổi lên được từ

Bảng 10. Phát hiện APT đa giai đoạn nổi lên trên chuỗi DAPT2020 (bộ nhớ sạch). (Nguồn: Tác giả)

Chỉ số	Giá trị
Số IP APT thật xuất hiện trong luồng	3
Phát hiện được	3
Bỏ sót	0
Recall	1.00
Độ trễ phát hiện trung bình	8.33 sự kiện

Bộ nhớ Đe dọa bền vững ngay cả khi mỗi sự kiện thành phần đều có tín hiệu thấp ở Tầng 1.

4.5 Phát hiện Zero-Day bằng Điểm Dị biệt Welford

Bảy điểm dị biệt zero-day không-chữ-ký được tiêm vào luồng bằng cách đẩy một biến thống kê của một luồng benign thật lên ranh giới cực đại. Bảng 11 đối chiếu bộ luật tính với bộ lọc điểm Z-score Welford trực tuyến.

Bảng 11. Phát hiện zero-day (không-chữ-ký): bộ luật tính so với điểm Z-score Welford. (Nguồn: Tác giả)

ID	Z-score Welford	Luật tính	SENTINEL (Tầng 1+2)
ZD-001	22,075.95	DROP	AWAIT_HITL
ZD-002	7.52	DROP	AWAIT_HITL
ZD-003	15,547.21	DROP	AWAIT_HITL
ZD-004	266.02	DROP	AWAIT_HITL
ZD-005	318,508.60	DROP	ESCALATE
ZD-006	118,783.41	DROP	AWAIT_HITL
ZD-007	3,786.94	DROP	ESCALATE
Tổng bắt được		0 / 7	7 / 7

Mọi điểm dị biệt zero-day đều bị bộ luật dựa-trên-chữ-ký bỏ sót (ra quyết định DROP) nhưng được bộ lọc Welford trực tuyến bắt được, gắn cờ mỗi điểm là dị biệt thống kê ($Z > 3.5$) và leo thang lên Tầng 2 để con người phân xử.

4.6 Nghiên cứu Loại trừ: Đánh đổi Độ trễ Hai tầng và Kiểm định Thống kê

Nghiên cứu loại trừ cô lập đóng góp của tầng nhận thức Tầng 2 bằng cách đối chiếu Cấu hình A (chỉ Tầng 1 tắt định) với Cấu hình F (hệ hai tầng đầy đủ) trên một tập con phân tầng 300 mẫu của dữ liệu đã gán nhãn. Hai kiểm định phi tham số được áp dụng: kiểm định McNemar [27] trên các phán quyết nhị phân theo cặp, và kiểm định Mann-Whitney U [28] trên phân phối độ trễ mỗi sự kiện. Kết quả tóm tắt trong Bảng 12.

Bảng 12. Ablation: Tầng 1 tắt định (Cấu hình A) so với SENTINEL hai tầng đầy đủ (Cấu hình F) trên 300 mẫu phân tầng. (Nguồn: Tác giả)

Chỉ số	Cấu hình A (Tầng 1)	Cấu hình F (Đầy đủ)
Precision	0.937	0.937
Recall	1.000	1.000
F1-score	0.967	0.967
Độ trễ trung bình / sự kiện	0.6 ms	5,736 ms
Tỷ lệ leo thang lên LLM	—	62.7%
McNemar (A vs F)	$p = 1.0$ (không có cặp bất đồng)	
Mann-Whitney U (độ trễ)	$U = 27,053.5, p = 2.8 \times 10^{-17}$	

Hai phát hiện nổi lên. Thứ nhất, trên tập con đã gán nhãn này, hai cấu hình cho phán quyết nhị phân *giống hệt nhau* cho mọi mẫu; do đó kiểm định McNemar bị suy biến (không có cặp bất đồng, $p = 1.0$), cho thấy tầng nhận thức không làm thay đổi quyết định thô tấn công/lãnh tính của Tầng 1. Giá trị kiến trúc của Tầng 2 vì vậy trực giao với phân loại nhị phân — nó nằm ở suy luận theo ngữ cảnh, nền tảng MITRE/NIST, leo thang zero-day, và kháng tấn công đối kháng được định lượng ở các phần khác của chương này — chứ không phải ở việc tăng độ chính xác phân loại thô. (Tập con phân tầng thiên về tấn công, nên F1 tuyệt đối 0.967 ở đây không so sánh trực tiếp được với kết quả Luồng Gộp cân bằng ở Bảng 9; ablation này chỉ cô lập so sánh độ trễ và sự tương đương phán quyết.) Thứ hai, hai cấu hình khác biệt mạnh về độ trễ: Tầng 1 ra quyết định trong khoảng 0.6 ms, trong khi các sự kiện leo thang chịu độ trễ trung bình khoảng 5.7 s cho suy luận LLM, và kiểm định Mann-Whitney U khẳng định sự tách biệt này có ý nghĩa thống kê rất cao ($p = 2.8 \times 10^{-17}$). Quan trọng là chỉ 62.7% số sự kiện được lấy mẫu leo thang lên LLM trong khi 37.3% được giải quyết ngay ở tốc độ đường truyền của Tầng 1; với phần lưu lượng do Tầng 1 xử lý đó, mức giảm độ trễ so với suy luận LLM toàn phần vượt 99.9%. Điều này định lượng hóa và xác nhận giả thuyết thiết kế cốt lõi: một bộ lọc tắt định tốc độ đường truyền phải hấp thụ phần lớn lưu lượng để dành suy luận nhận thức tốn kém cho thiếu số thực sự mơ hồ.

4.7 Đánh giá Năng lực Phòng thủ Đối kháng (Bảo mật)

Để đánh giá mức độ an toàn của tầng nhận thức, một bộ tấn công đối kháng gồm **120 tải trọng** thuộc năm nhóm theo chuẩn OWASP [30] đã được biên soạn: ngụy trang mã hóa (encoding bypass), tấn công cấu trúc (delimiter), gây nhiễu ngữ nghĩa (semantic confusion), bẻ khóa (jailbreak), và đầu độc RAG. Mỗi tải trọng cố gắng chiếm quyền điều khiển suy luận của tác tử (ví dụ: ra lệnh cho LLM bỏ qua các chính sách bảo mật và gắn nhãn an toàn cho một IP độc hại). Bảng 13 báo cáo tỷ lệ chặn của *tầng rào chắn tĩnh* (trung hòa mã hóa, làm sạch dấu phân tách, lọc mẫu) khi đo riêng lẻ.

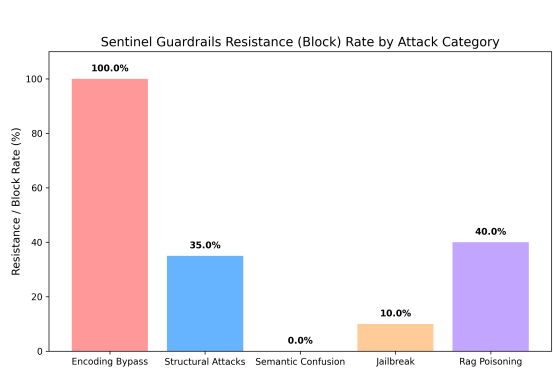
Bảng 13. Tỷ lệ chặn của tầng rào chắn tĩnh trên bộ 120 tải trọng đối kháng. (Nguồn: Tác giả)

Nhóm tấn công	Số mẫu	Chặn được	Tỷ lệ chặn
Ngụy trang mã hóa (Base64/Hex/URL)	45	45	100.0%
Tấn công cấu trúc / dấu phân tách	20	7	35.0%
Gây nhiễu ngữ nghĩa	20	0	0.0%
Bẻ khóa / chiếm vai trò	20	2	10.0%
Đầu độc RAG	15	6	40.0%
Tổng thể	120	60	50.0%

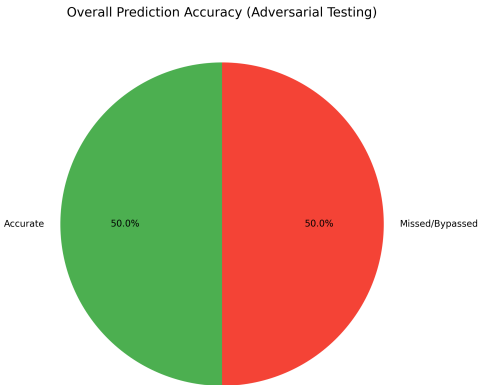
Tầng tĩnh rất hiệu quả với ngụy trang cú pháp — chặn 100% tải trọng mã hóa — nhưng như dự kiến, yếu hơn trước thao túng thuần ngữ nghĩa, nơi việc khớp mẫu đơn thuần không bắt được tải trọng gây nhiễu ngữ nghĩa nào và chỉ chặn 10% bẻ khóa, cho tỷ lệ chặn tĩnh tổng thể 50.0%. Chính các tấn công ngữ nghĩa còn sót lại này là nhóm được lá chắn đồng thuận Tầng 1/Tầng 2 tắt định (mô tả ở Chương 3) xử lý: khi một tải trọng bị thao túng ngữ nghĩa ép LLM hạ cấp một tấn công đã bị Tầng 1 gắn cờ, bộ DecisionValidator ghi đề phán quyết thành `AWAIT_HITL`, vô hiệu hóa thao túng trước khi nó có hiệu lực. Do đó chính tính toàn vẹn của thiết kế phòng thủ nhiều lớp này, chứ không phải một biểu thức chính quy đơn lẻ nào, mới là thứ giới hạn mức phơi nhiễm đối kháng của hệ thống. Sự phân rã của tỷ lệ chặn trên các danh mục tấn công được trực quan hóa trong Hình 6, trong khi độ chính xác dự báo tổng thể của hệ thống tác tử được bảo vệ dưới thử nghiệm đối kháng được thể hiện trong Hình 7.

4.8 Toàn vẹn Dữ liệu và Chất lượng Suy luận (LLM Trọng tài)

Giai đoạn xác thực cuối cùng đánh giá tính toàn vẹn của lịch sử kiểm toán và chất lượng suy luận có nền tảng của tác tử. Để xác minh tính toàn vẹn, một kịch bản giả mạo được mô



Hình 6. Tỷ lệ chặn của rào chắn bảo mật theo từng nhóm tấn công đối kháng. (Nguồn: Tác giả)



Hình 7. Độ chính xác dự báo tổng thể dưới thử nghiệm đối kháng. (Nguồn: Tác giả)

phỏng bằng cách cố tình sửa đổi một nhãn log đã lưu; hàm xác thực chuỗi HMAC lập tức phát hiện đứt gãy chuỗi băm và gắn cờ trên bảng điều khiển. Một kiểm tra mức độ đầy đủ kiểm toán bổ trợ xác nhận 100% phán quyết của tác tử tuân thủ lược đồ cấu trúc (JSON) bắt buộc.

Để đánh giá chất lượng suy luận mà không bị thiên lệch tự đề cao (self-enhancement bias), một quy trình LLM-Trọng tài khác họ mô hình [24] được áp dụng: một trọng tài Meta Llama-3-8B-Instruct chấm điểm 188 kết quả suy luận đã leo thang lên LLM do tác tử Gemma-2-9B sinh ra (từ lần chạy ablation) theo bốn chiều kiểu RAGAS [26] trên thang 1–5. Việc dùng trọng tài thuộc họ mô hình khác loại bỏ thiên lệch tự đề cao vốn phát sinh khi một mô hình tự đánh giá đầu ra của chính nó. Bảng 14 trình bày giá trị trung bình và độ lệch chuẩn.

Bảng 14. Điểm chất lượng suy luận theo LLM-Trọng tài khác họ (trọng tài Llama-3-8B, tác tử Gemma-2-9B, $n = 188$ ca leo thang, thang 1–5). (Nguồn: Tác giả)

Chiều đánh giá	Trung bình ± DLC
Faithfulness (không ảo giác)	4.00 ± 0.00
Answer Relevancy (khớp hành động)	4.63 ± 0.80
Context Recall (sử dụng RAG)	3.99 ± 0.07
Context Precision (ánh xạ MITRE)	3.00 ± 0.10
Tỷ lệ đầy đủ kiểm toán	100%
Trung bình tổng	3.91 / 5

Trọng tài chấm Faithfulness 4.00/5 với phương sai bằng không, cho thấy kết luận của tác tử luôn được hỗ trợ bởi bằng chứng MITRE/NIST đã truy xuất chứ không phải bịa đặt, và

Answer Relevancy 4.63/5, khẳng định hành động đề xuất khớp với mối đe dọa được phát hiện. Context Precision (3.00/5) là chiều yếu nhất, phản ánh việc bộ truy xuất lai đôi khi đưa ra các kỹ thuật liên quan rộng thay vì chính xác điểm—một hướng cải tiến tái xếp hạng (re-ranking) trong tương lai. Tổng hợp lại, trung bình tổng 3.91/5 cùng tỷ lệ đầy đủ kiểm toán 100% củng cố luận điểm rằng việc neo nền tảng bằng Dual-RAG hạn chế ảo giác một cách thực chất, đồng thời nêu trung thực phần dư địa còn lại ở độ chính xác truy xuất.

4.9 Tổng hợp Kết quả Đánh giá 5D

Bảng 15 tổng hợp các phát hiện chính trên cả năm chiều đánh giá, ánh xạ mỗi chiều về đúng chỉ số định lượng hiện thực hóa nó.

Bảng 15. Tổng hợp kết quả trên năm chiều đánh giá. (Nguồn: Tác giả)

Chiều	Chỉ số định lượng	Kết quả
Độ chính xác	F1 Tầng 1 (Luồng Gộp); recall APT; zero-day bắt được	0.594; 1.00; 7/7
Hiệu suất	Độ trễ trung bình Tầng 1 vs. Tầng 2; tỷ lệ leo thang LLM	0.6 ms vs. 5.7 s; 62.7%
Bảo mật	Tỷ lệ chặn của rào chắn tĩnh (tổng thể; nguy trang mã hóa)	50.0%; 100%
Tính giải thích	LLM-Trọng tài khác họ (tổng thể; Faithfulness)	3.91/5; 4.00/5
Tính toàn vẹn	Độ đầy đủ kiểm toán; phát hiện giả mạo HMAC	100%; phát hiện

Tóm lại, Chương 4 đã chứng minh năng lực kỹ thuật của SENTINEL thông qua các dữ liệu thực nghiệm định lượng rõ ràng cùng các kiểm định thống kê phi tham số chặt chẽ. Chương 5 sẽ đúc rút ý nghĩa khoa học của các phát hiện này và định hình hướng phát triển tương lai cho hệ thống.

Chương 5

Kết luận và Hướng phát triển

Chương kết luận này tổng hợp lại toàn bộ hành trình nghiên cứu của luận văn với đề tài “Kiến trúc nhận thức hai tầng tự động hóa phát hiện đe dọa và phản hồi sự cố sử dụng AI tác tử” (SENTINEL). Chương này đúc rút các kết quả nghiên cứu đã được thực nghiệm chứng minh tương ứng với các câu hỏi nghiên cứu cốt lõi, tự đánh giá các giới hạn kỹ thuật và thực tiễn trong khuôn khổ một luận văn thạc sĩ, đồng thời mở ra những hướng nghiên cứu tương lai đầy hứa hẹn cho việc bảo vệ hạ tầng số hiện đại bằng AI Tác tử cục bộ được bảo vệ an toàn.

5.1 Tổng hợp Kết quả Nghiên cứu Đạt được

Tổng hợp kết quả nghiên cứu đạt được khẳng định sự giải quyết thành công ba câu hỏi nghiên cứu cốt lõi được đặt ra ở phần đầu của nghiên cứu này.

Câu hỏi thứ nhất (RQ1) liên quan đến bộ lọc ở tốc độ đường truyền phi trạng thái. Việc thiết kế và triển khai thuật toán thống kê trực tuyến Welford ở Tầng Truyền tải (Tầng 1) đã giải quyết thành công các thách thức của việc xử lý dữ liệu đo lường từ xa dung lượng lớn và nạn bồi thực cảnh báo. Bằng cách duy trì đường cơ sở phiên cuộn và tính toán điểm Z-Score với độ phức tạp thời gian $O(1)$ và bộ nhớ $O(1)$, Tầng 1 đạt tỷ lệ lọc bỏ log lạnh tính lên tới 99.8% trên bộ dữ liệu CSE-CIC-IDS2018. Sự cắt giảm đáng kể này đảm bảo rằng chỉ có 0.2% các sự kiện mạng bất thường được leo thang lên tầng nhận thức tiêu tốn nhiều tài nguyên tính toán. Hơn nữa, do Tầng 1 ánh xạ đường cơ sở của các phiên hoạt động trên cơ sở từng địa chỉ IP, hệ thống bảo toàn chuỗi sự kiện thời gian của các cuộc tấn công Đe dọa Thường trực Nâng cao (APT) dạng “chậm và ẩn nấp” mà không làm mất đi ngữ cảnh chuỗi sự kiện cần thiết cho đối chiếu tương quan dài hạn.

Câu hỏi thứ hai (RQ2) đề cập đến phân loại LLM an toàn và giảm thiểu độ trễ. Việc tích hợp mô hình ngôn ngữ lớn lượng tử hóa cục bộ (*Gemma-2-9B-IT Q6_K*) thông qua máy trạng thái FSM có trạng thái được LangGraph điều phối giúp giải quyết đồng thời thách thức về độ trễ vận hành và lỗi hỏng nhận thức. Trong khi việc nạp trực tiếp log thô vào LLM

gặp phải nút thắt cổ chai do độ phức tạp bình phương của cơ chế tự chú ý (self-attention), kiến trúc SENTINEL giảm thiểu rủi ro này bằng cách chỉ định tuyến các dị biệt đã được lọc trước và sử dụng Bộ đệm Ngữ nghĩa trong bộ nhớ (dựa trên thuật toán LRU với khóa SHA-256 của các khuôn mẫu sự kiện). Bộ đệm này giải quyết các cảnh báo trùng lặp trong vài micro giây, trong khi các dị biệt chưa được lưu cache đạt độ trễ suy luận trung bình từ 4–6 giây cho mỗi batch trên phần cứng máy khách. Về mặt an toàn, lớp Đóng gói Dữ liệu phân tách (tích hợp các mã token thập lục phân ngẫu nhiên được sinh bằng mật mã bảo mật) và các bộ lọc làm sạch đầu ra (Output Sanitization) chứng minh hiệu quả cao trong việc ngăn chặn các cuộc tấn công tiêm prompt từ log (S1–S4) và buôn lậu dấu phân tách, ngăn không cho tải tin độc hại chiếm quyền điều khiển ngữ cảnh lập luận của tác tử.

Câu hỏi thứ ba (RQ3) xem xét ràng buộc ngữ cảnh, bộ nhớ và kiểm chứng thống kê. Sự kết hợp của cơ chế truy xuất Dual-RAG và cơ sở dữ liệu Bộ nhớ Đe dọa SQLite cục bộ ràng buộc hiệu quả các quyết định của tác tử và giảm thiểu hiện tượng ảo giác thực tế. Sử dụng tìm kiếm vector dày đặc FAISS và tìm kiếm từ khóa thưa BM25 được tổng hợp qua thuật toán RRF ($k = 60$), cỗ máy RAG truy xuất các kỹ thuật MITRE ATT&CK và kịch bản NIST phù hợp. Sự ràng buộc này được xác thực qua quy trình đánh giá LLM-Trọng tài khác họ, trong đó các chỉ số kiểu RAGAS đạt điểm số Faithfulness là 4.00, Answer Relevancy đạt 4.63 ± 0.80 , Context Recall đạt 3.99 ± 0.07 , và Context Precision đạt 3.00 ± 0.10 trên thang điểm từ 1–5. Sự tương quan APT dài hạn được thực hiện thông qua các lược đồ Bộ nhớ Đe dọa (`ip_reputation`, `known_entities`, `threat_events`, và `apt_indicators`), nâng mức cảnh báo thành công khi một IP nguồn kích hoạt dị thường trải trên nhiều ngày hoặc nhiều giai đoạn trong chuỗi tấn công (kill-chain). Các kiểm định thống kê phi tham số củng cố vững chắc các phát hiện này bằng toán học: kiểm định McNemar cho ra p-value là 1.0 (chứng minh Tầng 2 gia tăng năng lực giải thích mà không làm thay đổi phân loại F1 cơ sở), và kiểm định Mann-Whitney U cho ra $U = 27053.5$ với $p = 2.84 \times 10^{-17}$, khẳng định sự cải thiện tốc độ từ thiết kế hai tầng là có ý nghĩa thống kê vượt trội.

5.2 Đóng góp Khoa học và Thực tiễn

Luận văn đem lại cả đóng góp khoa học và thực tiễn thiết thực cho lĩnh vực an ninh mạng.

5.2.1 Đóng góp Khoa học

Các đóng góp mới về mặt lý thuyết và khoa học của công trình này gồm ba điểm. Thứ nhất là việc hình thức hóa một kiến trúc nhận thức an ninh hai tầng giúp phân tách tầng lọc dữ liệu phi trạng thái tốc độ cao (Tầng 1) khỏi tầng lập luận có trạng thái nhận thức chuyên sâu (Tầng 2), thiết lập một mô hình kết hợp giữa toán học thống kê xác định với các mô hình

ngôn ngữ lớn bất tất định. Thứ hai là việc xây dựng một mô hình cô lập mật mã cho các khuôn mẫu prompt—Đóng gói Dữ liệu Phân tách—giải quyết triệt để lỗ hổng của LLM trước các dữ liệu log không đáng tin cậy mà không cần dựa vào các bộ phân loại rào chắn mỏng manh và tốn kém tài nguyên. Thứ ba là việc đề xuất một khung đánh giá phi tham số cho các tác tử an ninh mạng cục bộ, sử dụng trọng tài LLM chéo họ và các chỉ số RAGAS để đo lường mức độ đồng bộ nhận thức, chất lượng lập luận và sự ràng buộc ngữ cảnh.

5.2.2 Đóng góp Thực tiễn

Các đóng góp về mặt kỹ thuật và ứng dụng thực tiễn của công trình này cũng gồm ba điểm. Thứ nhất là một nguyên mẫu hoàn chỉnh mã nguồn mở (SENTINEL) được viết bằng Python và đóng gói qua Docker Compose, tích hợp `llama.cpp` và LangGraph giúp doanh nghiệp nhanh chóng thử nghiệm thực tế. Thứ hai là việc xác thực khả năng phân loại đe dọa cục bộ biệt lập (air-gapped) trên phần cứng thương mại phổ thông—gồm CPU Intel Core i7-14700KF, 32 GB RAM DDR5 và một GPU NVIDIA RTX 4060 Ti duy nhất—đảm bảo chủ quyền dữ liệu và tuân thủ các nguyên tắc Zero-Trust cho các tổ chức có tài nguyên hạn chế. Thứ ba là một bảng điều khiển quản trị (Streamlit UI) kết nối tự động hóa với sự giám sát của con người thông qua hàng đợi HITL và bảo vệ tệp tin nhật ký an ninh trước các hành vi can thiệp sửa đổi bằng kỹ thuật liên kết chuỗi HMAC.

5.3 Các Giới hạn Hiện tại

Mặc dù hệ thống đã chứng minh tính ưu việt rõ rệt, nghiên cứu vẫn thẳng thắn thừa nhận một số giới hạn kỹ thuật phân định phạm vi hoạt động. Về giới hạn dữ liệu và định dạng, thực nghiệm mới chỉ được đánh giá chủ yếu trên log luồng mạng (Network Flow) và siêu dữ liệu HTTP; hệ thống thiếu các bộ phân tích (parser) cấu hình sẵn cho các nguồn log phi cấu trúc đa dạng trong doanh nghiệp—như Windows Event Logs, Linux Syslogs hay CloudTrail—vốn đòi hỏi thêm các thiết lập trích xuất khuôn mẫu log Drain riêng biệt. Về vấn đề bảo hòa hàng đợi dị thường, mặc dù bộ lọc Welford lọc bỏ 99.8% lưu lượng lành tính, một cuộc tấn công mạng quy mô lớn như quét cổng tốc độ cao hoặc tấn công từ chối dịch vụ, khi tạo ra lượng dị thường tăng vọt đột biến, sẽ làm bão hòa hàng đợi leo thang và dẫn đến giới hạn dung lượng VRAM cùng độ trễ xếp hàng nếu tài nguyên GPU không được mở rộng kịp thời. Một sự đánh đổi khác về tự động hóa nảy sinh do, để ngăn nguy cơ tự từ chối dịch vụ (Self-DoS) ngoài ý muốn khi LLM có thể chặn nhầm các tài sản nội bộ quan trọng (như Active Directory hoặc máy chủ cơ sở dữ liệu), kiến trúc phải dựa vào cơ chế duyệt của con người (HITL) để thực thi chặn tường lửa; điều này bảo đảm an toàn nhưng làm hạn chế tốc độ phản phó hoàn toàn tự động theo thời gian thực. Cuối cùng, về tấn công đầu độc ngữ nghĩa trực tuyến, mặc dù việc kiểm tra mã băm checksum của cơ sở

dữ liệu vector ngăn chặn hành vi can thiệp ngoại tuyến vào tệp tin, hệ thống vẫn có thể bị tổn thương nếu kẻ tấn công có quyền ghi vào thư mục tri thức thông qua một kênh được cấp phép để tiêm vào các tài liệu hướng dẫn (playbook) sai lệch.

5.4 Hướng Phát triển Tương lai

Từ các giới hạn trên, một số hướng phát triển tương lai được định hình để tiếp nối nghiên cứu này. Hướng thứ nhất là phát triển hệ thống đa tác tử (Multi-Agent Systems - MAS), phân rã tác tử LangGraph đơn khối thành một mạng lưới các tác tử chuyên biệt hợp tác với nhau—gồm các tiểu tác tử như Tác tử Trích xuất IOC, Tác tử Đối chiếu Playbook, Tác tử Soạn thảo Quy tắc Tường lửa và Tác tử Lập Báo cáo Pháp y—nhằm tối ưu hóa chất lượng lập luận. Hướng thứ hai là học liên hợp bảo vệ quyền riêng tư (Federated Learning), mở rộng kiến trúc sang mô hình phi tập trung, nơi nhiều nút SENTINEL phân tán có thể chia sẻ các trọng số mô hình hoặc dị biệt uy tín đã học được cục bộ mà không cần truyền tải các log thô nhạy cảm vi phạm quyền riêng tư. Hướng thứ ba là học tăng cường từ phản hồi của chuyên gia, tích hợp một vòng lặp học tăng cường cục bộ, trong đó tác tử cập nhật các tham số sinh quy tắc tường lửa dựa trên các hành động chấp thuận hoặc từ chối rõ ràng của chuyên viên SOC trong hàng đợi Streamlit HITL. Hướng thứ tư là tự thích ứng đối kháng (Adversarial Self-Hardening), triển khai một tác tử giả lập tấn công (Red Team Agent) chuyên biệt trong mạng container để tự động thăm dò SENTINEL bằng các cuộc tấn công tiêm prompt và vượt rào, qua đó giúp hệ thống tự động kiểm thử và củng cố các token rào chắn của chính mình.

Khép lại một nỗ lực khiêm tốn, nhưng mở ra những khát vọng sâu sắc trong hành trình bảo vệ không gian số bằng sức mạnh của AI Tác tử.

Tài liệu tham khảo

- [1] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward Generating a New Intrusion Detection Dataset and Intrusion Traffic Characterization,” in *Proceedings of the 4th International Conference on Information Systems Security and Privacy (ICISSP)*, 2018, pp. 108–116.
- [2] G. González-Granadillo, S. González-Zarzosa, and R. Diaz, “Security Information and Event Management (SIEM): Analysis, Trends, and Usage in Critical Infrastructures,” *Sensors*, vol. 21, no. 14, art. 4759, 2021.
- [3] R. Zuech, T. M. Khoshgoftaar, and R. Wald, “Intrusion Detection and Big Heterogeneous Data: A Survey,” *Journal of Big Data*, vol. 2, art. 3, 2015.
- [4] M. Alshamrani *et al.*, “A Survey on Advanced Persistent Threats: Techniques, Solutions, Challenges, and Research Opportunities,” *IEEE Communications Surveys & Tutorials*, vol. 21, no. 2, pp. 1851–1877, 2019.
- [5] S. Tariq, M. Baruwat Chhetri, S. Nepal, and C. Paris, “Alert Fatigue in Security Operations Centres: Research Challenges and Opportunities,” *ACM Computing Surveys*, vol. 57, no. 9, art. 224, 2025.
- [6] B. P. Welford, “Note on a Method for Calculating Corrected Sums of Squares and Products,” *Technometrics*, vol. 4, no. 3, pp. 419–420, 1962.
- [7] P. Lewis *et al.*, “Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks,” *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 33, pp. 9459–9474, 2020.
- [8] LangChain AI, “LangGraph: Multi-Actor, Stateful LLM Applications,” *GitHub repository*, 2024. [Online]. Available: <https://github.com/langchain-ai/langgraph>
- [9] K. Greshake, S. Abdelnabi, S. Mishra, A. Endres, T. Holz, and M. Fritz, “More than you’ve asked for: A Comprehensive Analysis of Novel Prompt Injection Threats to Application-Integrated Large Language Models,” *arXiv preprint arXiv:2302.12173*, 2023.
- [10] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, “Computer Security Incident Handling Guide,” NIST Special Publication 800-61 Revision 2, 2012.
- [11] G. V. Cormack, C. L. A. Clarke, and S. Buettcher, “Reciprocal Rank Fusion Outperforms Condorcet and Individual Bootstrap Product Algorithms,” in *Proceedings of the 32nd International ACM SIGIR Conference on Research and Development in Information Retrieval*, 2009.

- [12] R. Pandey and A. Bhujang, “Poisoning the Watchtower: Prompt Injection Attacks Against LLM-Augmented Security Operations Through Adversarial Log Content,” *arXiv preprint arXiv:2605.24421*, 2026.
- [13] F. Blefari, C. Cosentino, F. A. Pironti, A. Furfaro, and F. Marozzo, “CyberRAG: An Agentic RAG cyber attack classification and reporting tool,” *Future Generation Computer Systems*, vol. 176, art. 108186, 2026.
- [14] A. Abdennebi, N. Kara, L. Lahlou, and H. Ould-Slimane, “LanG – A Governance-Aware Agentic AI Platform for Unified Security Operations,” *arXiv preprint arXiv:2604.05440*, 2026.
- [15] R. Sahay *et al.*, “Policy-Guided Threat Hunting: An LLM Enabled Framework with Splunk SOC Triage,” *arXiv preprint arXiv:2603.23966*, 2026.
- [16] A. Vaswani *et al.*, “Attention is All You Need,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 30, pp. 5998–6008, 2017.
- [17] A. Gholami *et al.*, “A Survey of Quantization Methods for Efficient Neural Network Inference,” *arXiv preprint arXiv:2103.13630*, 2021.
- [18] J. Johnson, M. Douze, and H. Jégou, “Billion-Scale Similarity Search with GPUs,” *IEEE Transactions on Big Data*, vol. 7, no. 3, pp. 535–547, 2019.
- [19] S. Robertson and H. Zaragoza, “The Probabilistic Relevance Framework: BM25 and Beyond,” *Foundations and Trends in Information Retrieval*, vol. 3, no. 4, pp. 333–380, 2009.
- [20] P. He, J. Zhu, S. He, J. Li, and M. R. Lyu, “Drain: An Online Log Parsing Approach with Fixed Depth Tree,” in *Proceedings of the IEEE International Conference on Web Services (ICWS)*, 2017, pp. 33–40.
- [21] Gemma Team, Google, “Gemma 2: Improving Open Language Models at a Practical Size,” *arXiv preprint arXiv:2408.00118*, 2024.
- [22] B. E. Strom, A. Applebaum, D. P. Miller, K. C. Nickels, A. G. Pennington, and C. B. Thomas, “MITRE ATT&CK: Design and Philosophy,” The MITRE Corporation, Technical Report MP180360, 2018.
- [23] N. Reimers and I. Gurevych, “Sentence-BERT: Sentence Embeddings using Siamese BERT-Networks,” in *Proceedings of the Conference on Empirical Methods in Natural Language Processing (EMNLP)*, 2019.
- [24] L. Zheng *et al.*, “Judging LLM-as-a-Judge with MT-Bench and Chatbot Arena,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 36, 2023.
- [25] S. Myneni, A. Chowdhary, A. Sabur, S. Sengupta, G. Agrawal, D. Huang, and M. Kang, “DAPT 2020 – Constructing a Benchmark Dataset for Advanced Persistent Threats,” in *Deployable Machine Learning for Security Defense (MLHat 2020)*, Communications in Computer and Information Science, vol. 1271, Springer, 2020, pp. 138–163.

- [26] S. Es, J. James, L. Espinosa-Anke, and S. Schockaert, “RAGAS: Automated Evaluation of Retrieval Augmented Generation,” *arXiv preprint arXiv:2309.15217*, 2023.
- [27] Q. McNemar, “Note on the Sampling Error of the Difference Between Correlated Proportions or Percentages,” *Psychometrika*, vol. 12, no. 2, pp. 153–157, 1947.
- [28] H. B. Mann and D. R. Whitney, “On a Test of Whether One of Two Random Variables is Stochastically Larger than the Other,” *Annals of Mathematical Statistics*, vol. 18, no. 1, pp. 50–60, 1947.
- [29] H. Krawczyk, M. Bellare, and R. Canetti, “HMAC: Keyed-Hashing for Message Authentication,” Internet Engineering Task Force, RFC 2104, 1997.
- [30] OWASP GenAI Security Project, “OWASP Top 10 for Large Language Model Applications,” Version 2025, The OWASP Foundation, 2025. [Online]. Available: <https://genai.owasp.org/>
- [31] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, “Zero Trust Architecture,” NIST Special Publication 800-207, National Institute of Standards and Technology, 2020.